

网络空间安全技术2024-2025学年期末复习

题型

选择20，判断10（每题1分）

名词解释

简答题

设计分析题

什么是网络安全意识

❖ 安全意识（Security awareness）

就是能够**认知**可能存在的安全问题，**明白**安全事故对组织的危害，恪守正确的行为方式，并且**清楚**在安全事故发生时所应采取的措施。

CH1 网络空间安全概述

1. 信息安全基本目标(CIA) (可能会考选择题)

机密性 (C,confidentiality), 完整性(I,integrity), 可用性(A,availability)

2. 什么是信息安全

信息本身的机密性 (Confidentiality)、完整性 (Integrity) 和可用性 (Availability) 的保持，即**防止**未经授权使用信息、**防止**对信息的非法修改和破坏、**确保**及时可靠地使用信息。

下面是背诵可以参考的，其实就是CIA三个方面内容

- 机密性：确保信息没有非授权的泄漏，不被非授权的个人、组织和计算机程序使用
- 完整性：确保信息没有遭到篡改和破坏
- 可用性：确保拥有授权的用户或程序可以及时、正常使用信息

！！延申问题：访问控制技术能否实现机密性保护！！

3. 网络空间的组成

来自中国《国家空间安全战略》

伴随信息革命的飞速发展，互联网、通信网、计算机系统、自动化控制系统、数字设备（设施）及其承载的应用、服务（操作）和数据等组成的网络空间，正在全面改变人们的生产生活方式，深刻影响人类社会历史发展进程

4. 网络空间的定义

网络空间是一个信息系统

网络空间四要素：网络空间载体（**设施**）；网络空间资源（**数据**）
网络活动主体（**用户**）；网络活动形式（**操作**）

网络空间载体：设施，信息通信技术系统的集合

网络操作对象：数据，表达人类所能理解的意图的信号状态

网络活动主体：用户，网络活动的主体要素，属于人的代理

网络活动形式：操作，对数据的加工、存储、传输、展示等服务形式

- 设施：互联网、通信网、计算机系统、自动化控制系统、数字设备
- 操作：应用、服务

- 数据：数据
- 用户：人

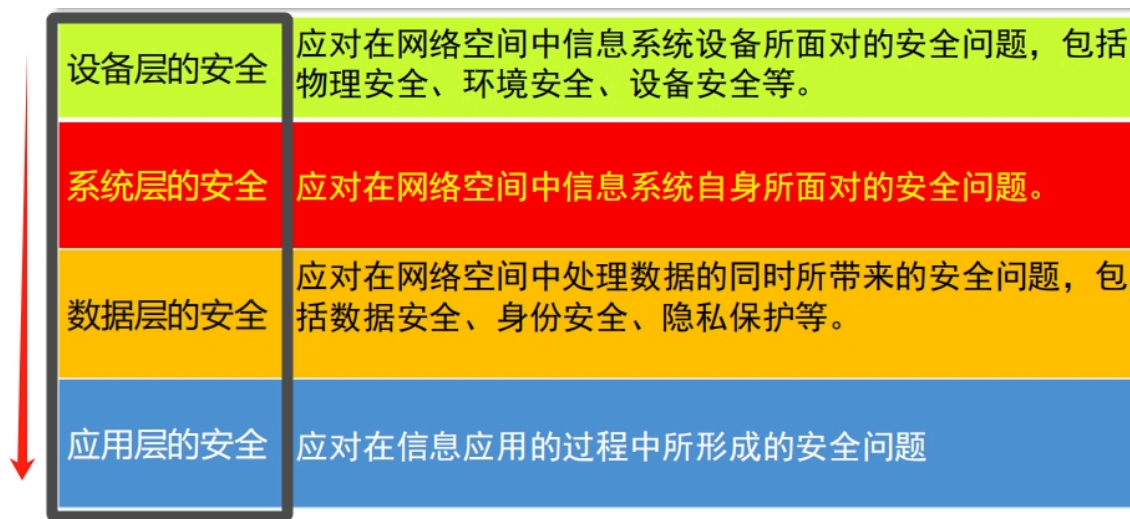
- 信息安全
- 应用安全
- 网络安全
- 因特网安全

必背!!!!!!! (主观意愿, 但是fy强调了这一部分)

网络空间是一种人造的电磁空间(必答必背, 后面的内容是四要素, 背不齐的话只会扣一丢丢分数, 但是如果定义为4分的话, 电磁空间会占2分), 其以互联网、各种通信系统与电信网、各种传播系统与广电网、各种计算机系统、各类关键工业设施中的嵌入式处理器和控制器等信息通信技术基础设施为载体, 用户通过在其上对数据进行创造、存储、改变、传输、使用、展示等操作, 以实现特定的信息通信技术活动。

5. 网络空间安全的四层次模型

主要答出画框框的内容, 感觉会出在B卷里(偏主观)



CH2 网络空间安全风险及风险管理

1. 什么是网络空间安全风险(主观感觉会考)

放在最前面, 实在想不起来的话可以回答

了解风险+控制风险=管理风险

定义一: GB/Z 24364《信息安全风险管理指南》

信息安全风险管理是识别、控制、消除或最小化可能影响系统资源的不确定因素的过程。

定义二: 在组织机构内部识别、优化、管理风险, 使风险降低到可接受水平的过程。

2. 风险评估工具

风险评估工具

◆ 风险评估与管理工具

基于标准的工具，如基于NIST SP 800-30或ISO 27005开发的工具

基于知识的工具，综合各种风险分析方法，形成知识库，以此为基础完成综合评估

基于模型的工具，对典型系统的资产、威胁、脆弱性建立量化或半量化的模型

◆ 系统基础平台风险评估工具

脆弱性扫描工具 基于网络的扫描器、基于主机的扫描器、分布式网络扫描器、数据库脆弱性扫描器

渗透性测试工具 黑客工具、脚本文件

◆ 风险评估辅助工具

检查列表、入侵检测系统、安全审计工具、拓扑发现工具和资产信息收集系统，用于评估过程参考的评估指标库、知识库、漏洞库、算法库和模型库

3. 网络空间安全风险术语

资产(Asset)
威胁源(Threat Agent)
威胁(Threat)
脆弱性(Vulnerability)
控制措施(Countermeasure, safeguard, control)
可能性(Likelihood, Probability)
影响(Impact, loss)
风险(Risk)
残余风险(Residual Risk)

3.1 网络空间安全风险术语-资产

1. 资产是任何对组织有价值的东西，是要保护的对象。

2. 资产以多种形式存在（多种分类方法）

物理的（如计算设备、网络设备和存储介质等）和逻辑的（如体系结构、通信协议、计算程序和数据文件等）

硬件的（如计算机主板、机箱、显示器、键盘和鼠标等）和软件的（如操作系统软件、数据库管理软件、工具软件和应用软件等）

有形的（如机房、设备和人员等）和无形的（如品牌、信心和名誉等）

静态的（如设施和规程等）和动态的（如人员和过程等）；

技术的（如计算机硬件、软件和固件等）和管理的（如业务目标、战略、策略、规程、过程、计划和人员等）

3.2 网络空间安全风险术语-威胁

- 可能导致信息安全事故和组织信息资产损失的活动
- 威胁源采取恰当的威胁方式才可能引发风险
- 威胁举例（可能会出判断题，不想看文字的话看图也是ok的）

操作失误	滥用授权
行为抵赖	身份假冒
口令攻击	密钥分析
漏洞利用	拒绝服务
窃取数据	物理破坏
社会工程	



3.3 网络空间安全风险术语-脆弱性

- 漏洞和脆弱性等同，但是用脆弱性讲管理方面的内容更为合适
- 与信息资产有关的弱点或安全隐患
- 造成风险的內因
- 脆弱性**本身并不对资产构成危害 (! ! ! ! !)**，但是在一定条件得到满足时，脆弱性会被威胁源利用恰当的威胁方式对信息资产造成危害。
- 脆弱性举例

系统程序代码缺陷
 系统设备安全配置错误
 系统操作流程有缺陷
 维护人员安全意识不足

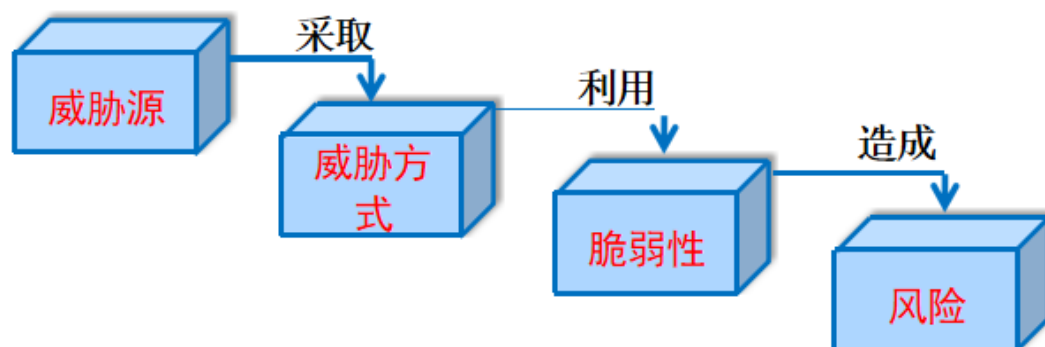
3.4 网络空间安全风险术语-控制措施

- 根据安全需求部署，用来防范威胁，降低风险的措施
- 举例

部署防火墙、入侵检测、审计系统
 测试环节
 操作审批环节
 应急体系
 终端U盘管理制度

3.5 网络空间安全风险术语-风险

- 指威胁源采用恰当的威胁方式利用脆弱性造成不良后果



如:网站存在SQL注入漏洞, 普通攻击者利用自动化攻击工具很容易控制网站, 修改网站内容, 从而损害国家政府部门声誉

下面的定义可以三选一进行描述

- GB/T 20984的定义: 网络空间安全风险
人为或自然的威胁利用信息系统及其管理体系中存在的脆弱性导致安全事件的发生及其对组织造成的影响。
- 网络空间安全风险是指一种特定的威胁利用一种或一组脆弱性造成组织的资产损失或损害的可能性
- 指信息资产的机密性、完整性和可用性遭到破坏的可能性 (感觉会出判断, 会把CIA的内容更改)

网络空间安全风险只考虑那些对组织有负面影响的事件 (可能出判断题的话语 主观)

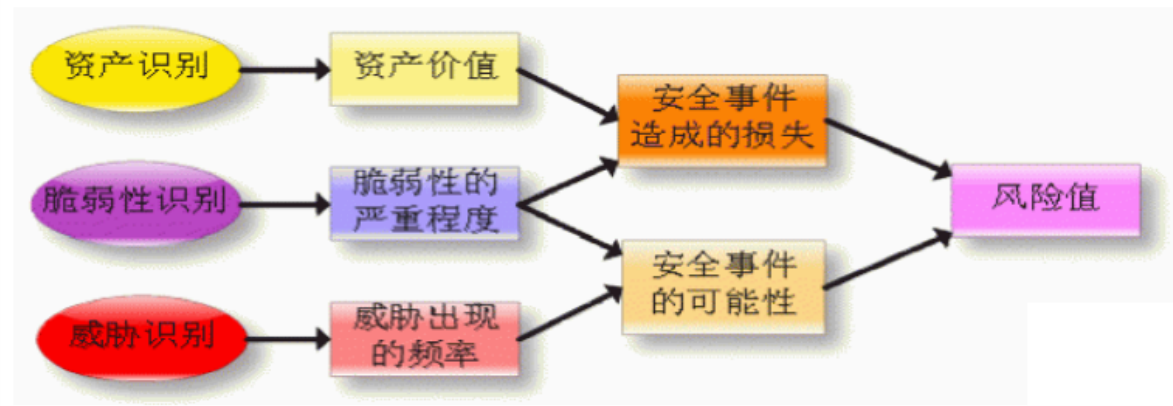
3.6 网络空间安全风险术语-残余风险

- 指采取了安全措施后, 信息系统仍然可能存在的风险
- 有些残余风险是在综合考虑了安全成本与效益后不去控制的风险
- 残余风险应受到密切监视, 它可能会在将来诱发新的安全事件 (此一时彼一时)

4. 常用的四类风险处置方法

- 减低风险
- 转移风险
- 规避风险
- 接受风险

5. 风险分析



$$\text{风险值} = R(A, T, V) = R(L(T, V), F(Ia, Va))$$

R表示安全风险计算函数
Ia表示安全事件所作用的资产价值
A表示资产
Va表示脆弱性严重程度
T表示威胁
L表示威胁利用资产的脆弱性导致安全事件的可能性
V表示脆弱性
F表示安全事件发生后造成的损失

6. 国产化替代究竟替什么？

替代被垄断的国外产品（自主可控！！！！把风险规避掉）

- 操作系统、硬件、大型计算机、数据库、存储都在受制

在第十四届中国(南京)国际软件产品和服务交易博览会上，倪光南院士讲到，目前，信息技术国产化替代在不同领域正在加速推进。包括：

- ◆ 国产桌面计算机技术体系对Wintel体系的替代
- ◆ 高端服务器和数据库对“IOE”的替代。ibm Oracle EMC

CH3 信息与网络空间安全保障

1. 信息系统安全保障

信息系统安全保障是在信息系统的**整个生命周期**中，从**技术、管理、工程**和**人员**等方面提出安全保障要求，确保信息系统的**保密性、完整性和可用性**，降低安全风险到可接受的程度，从而保障系统实现**组织机构的使命**

2. 安全模型的概念（ ）

2.1 什么是网络空间安全模型

- 通过建模的思想来解决网络安全管理问题，有效抵御外部攻击，保障网络安全。
- 安全模型用于精确和形式地描述信息系统的安全特征，解释系统安全相关行为。

2.2 为什么需要安全模型（ 半主观一下）

- 能准确地描述安全的重要方面与系统行为的关系。
- 能提高对成功实现关键安全需求的理解层次。
- 从中开发出一套安全性评估准则，和关键的描述变量。

3. PDR演变：PDRR模型

PDRR模型是：保护（Protect）、检测（Detect）、反应（React）、恢复（Restore）的有机结合。该模型强调的是自动故障恢复能力。

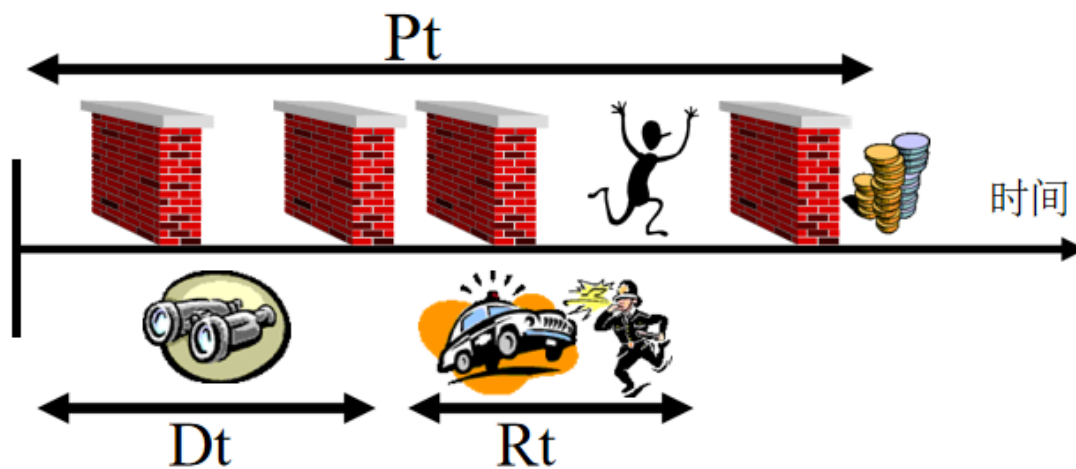


4. PDR演变:PPDR模型

PPDR的基于思想是:在整体的安全策略的控制和指导下，综合运用防护工具（如防火墙、身份鉴别、加密等）的同时，利用检测工具（如漏洞评估、入侵检测系统)了解和评估系统的安全状态，通过适当的响应将系统调整到一个比较安全的状态。保护、检测和响应组成了一个完整的、动态的安全循环。



4.1 PPDR模型中的数学法则



新定义: **$Pt > Dt + Rt$**

假设S系统的防护、检测和反应的时间关系如下:

Pt =防护时间(有效防御攻击的时间)
 Dt =检测时间(发起攻击到检测到的时间)
 Rt =反应时间(检测到攻击到处理完成时间)
 Et =暴露时间

系统防护、检测和反应的时间关系如下:

如果 $Pt > Dt + Rt$, 那么S是安全的;

如果 $Pt < Dt + Rt$, 那么 $Et = (Dt + Rt) - Pt$ 。

5. IATF-深度防御保障模型

信息保障技术框架 (Information Assurance Technical Framework, IATF)

- NSA制定的, 为保护美国政府和工业界的信息与信息技术设施提供技术指南。
- IATF的代表理论为“深度防御 (Defense-in-Depth) ”。
- 在关于实现信息保障目标的过程和方法上, IATF论述了系统工程、系统采购、风险管理、鉴别和鉴定以及生命周期支持等过程, 指出了一条较为清晰的建设信息保障体系的路子。

5.1 何谓“深度防御”?

IATF强调人、技术、操作这三个核心要素, 从多种不同的角度对信息系统进行防护。

IATF关注四个信息安全保障领域 (三保护一支撑)

- 本地计算环境
- 区域边界
- 网络和基础设施
- 支撑性基础设施

在此基础上, 对信息系统就可以做到多层防护, 实现组织的任务/业务运作。这样的防护被称为“深度防护战略 (Defense-in-Depth Strategy) ”。

5.2 IATF三要素

- **人 (People)**
 - 信息保障体系的核心，是第一位的要素，同时也是最脆弱的。
 - 基于这样的认识，安全管理在安全保障体系中愈显重要，包括意识培训、组织管理、技术管理、操作管理
- **技术 (Technology) :**
 - 技术是实现信息保障的重要手段。
 - 动态的技术体系：防护、检测、响应、恢复
- **操作 (Operation) :**
 - 也叫运行，构成安全保障的主动防御体系。
 - 也是将各方面技术紧密结合在一起的主动的过程，包括：
 - 风险评估、安全监控、安全审计
 - 跟踪告警、入侵检测、响应恢复

5.3 IATF的安全需求划分

IATF定义了四个主要的技术焦点领域：

- 本地计算环境
- 区域边界
- 网络和基础设施
- 支撑性基础设施

这四个领域构成了完整的信息保障体系所涉及的范围

在每个领域范围内， IATF都描述了其特有的安全需求和相应的可供选择的技术措施

6. DDOS事件处理 (主观感觉可能要考)

22	0.200263	192.168.1.51	10.10.10.13	TCP	46644 > netbios-ssn [SYN] Seq=0 Len=0 MSS=1460
23	0.210279	192.168.1.20	10.10.10.13	TCP	54611 > netbios-ssn [SYN] Seq=0 Len=0 MSS=1460
24	0.220299	192.168.1.58	10.10.10.13	TCP	31101 > netbios-ssn [SYN] Seq=0 Len=0 MSS=1460
25	0.230305	192.168.1.93	10.10.10.13	TCP	39174 > netbios-ssn [SYN] Seq=0 Len=0 MSS=1460
26	0.240320	192.168.1.74	10.10.10.13	TCP	7739 > netbios-ssn [SYN] Seq=0 Len=0 MSS=1460

Q：出现这种状态是什么攻击

A：基于SYN FLOOD的拒绝分布式攻击

SYN Flood攻击 (上图) :

此种攻击经过抓包分析可以看到, 大量的SYN请求发向目标地址, 而SYN包的源地址为大量的随机生成的虚假地址。

Q：SYN FLOOD有什么样的特征呢？

A：在目标主机上使用netstat -an命令可以看到大量syn连接, 处于syn_received状态

TCP	10.10.10.13:139	192.168.1.95:12295	SYN_RECEIVED
TCP	10.10.10.13:139	192.168.1.95:43613	SYN_RECEIVED
TCP	10.10.10.13:139	192.168.1.95:45626	SYN_RECEIVED
TCP	10.10.10.13:139	192.168.1.95:51567	SYN_RECEIVED
TCP	10.10.10.13:139	192.168.1.96:16653	SYN_RECEIVED
TCP	10.10.10.13:139	192.168.1.96:24637	SYN_RECEIVED
TCP	10.10.10.13:139	192.168.1.96:46674	SYN_RECEIVED
TCP	10.10.10.13:139	192.168.1.96:53784	SYN_RECEIVED
TCP	10.10.10.13:139	192.168.1.96:63246	SYN_RECEIVED
TCP	10.10.10.13:139	192.168.1.97:17252	SYN_RECEIVED
TCP	10.10.10.13:139	192.168.1.97:19265	SYN_RECEIVED

使用抗DDOS设备或其他专用防护设备来进行防护，默认参数下就 可以达到比较好的效果。

7. 常见应急事件

目前根据主机受到的攻击的表象可将木马病毒分为四类：

勒索病毒（勒索木马）：特征即磁盘文件被加密，一旦完成勒索过程则无法恢复文件，因此这类病毒以预防为主，安装杀毒软件并做好主机防黑工作及时打补丁，对重要文件要及时隔离备份；（🌈）

挖矿木马：特征即CPU和GPU异常占用过高，且有对矿池地址的解析。目前挖矿木马表现可有落地文件实现也可通过WMI等无落地文件实现；

远控木马：APT攻击的主流，复杂程度高，其特点是集成了攻击模块、控制模块、持久化模块等且有C2服务器；

普通木马：代指除开以上类型的其余木马类型等。

CH4 网络空间安全技术体系与技术

1. 信息系统安全体系框架

信息系统安全的总需求是物理安全、网络安全、信息内容安全、应用系统安全和安全管理的总和，安全的最终目标是确保信息的机密性、完整性、可用性、可控性和抗抵赖性，以及信息系统主体（包括用户、团体、社会和国家）对信息资源的控制。

完整的信息系统安全体系框架由技术体系、组织机构体系和管理体系共同构建。

2. 网络空间安全体系框架

管理体系

- 管理是信息系统安全的灵魂。
- 信息系统安全的管理体系由法律管理、制度管理和培训管理三个部分组成。

~~三分技术，七分管理~~；管理与技术并重

- 1) 法律管理是根据相关的国家法律、法规对信息系统主体及其与外界关联行为的规范和约束。
- 2) 制度管理是信息系统内部依据系统必要的国家、团体的安全需求制定的一系列内部规章制度。
- 3) 培训管理是确保信息系统安全的前提。

2. 安全机制

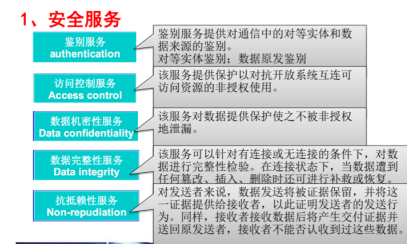


图 4.2：五个安全服务

八种基本的安全机制	其他安全机制
① 加密 ② 数字签名机制 ③ 访问控制机制 ④ 数据完整性机制 ⑤ 鉴别交换机制 ⑥ 通信业务流填充机制 ⑦ 路由选择控制机制 ⑧ 公证机制	① 可信功能模块（可信软硬件系统部件） ② 安全标记 ③ 事件检测 ④ 安全审计跟踪 ⑤ 安全恢复

3. 数据完整性机制

数据完整性是防止非法实体对交换数据的修改、插入、替换和删除，或者如果被修改、插入、替换和删除时可以被检测出来。数据完整性可以通过消息认证模式来保证。

完整性机制分类（可能出选择）

- 通过密码学提供完整性
- 通过上下文提供完整性
- 通过探测和确认提供完整性
- 通过阻止提供完整性

4. 数字签名机制（可能会考）

传统签名的基本特点：

- 能与被签的文件在物理上不可分割
- 签名者不能否认自己的签名
- 签名不能被伪造
- 容易被验证

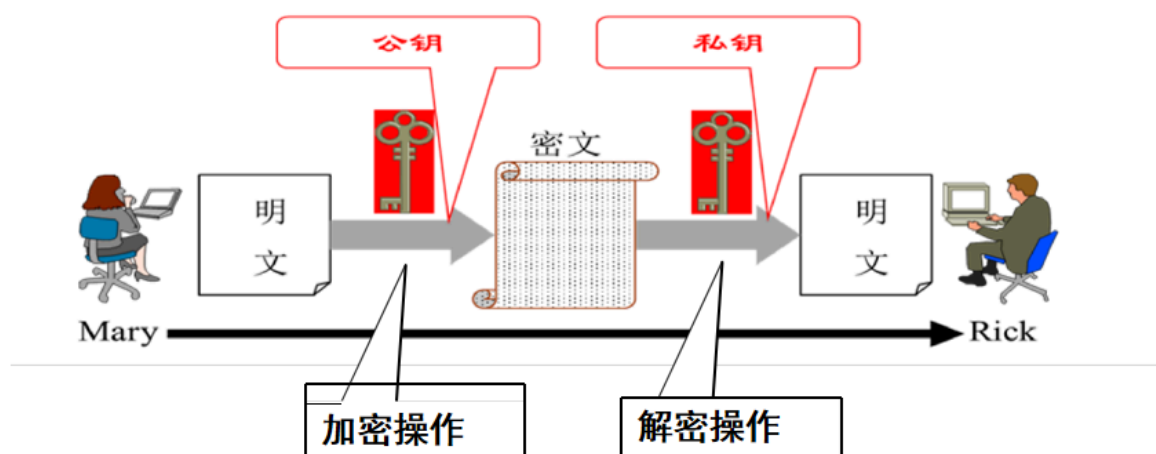
数字签名是传统签名的数字化，基本要求：

- 能与所签文件“绑定”
- 签名者不能否认自己的签名
- 签名不能被伪造
- 容易被验证

数字签名的特性

- **不可伪造性**：没有私钥，很难伪造一个合法的数字签名
- **抗抵赖性**：对普通数字签名，任何人可用签名者公钥验证签名的有效性
- **保证消息完整性**：可以防止消息被篡改

5. 公钥加密模型



加密与解密由不同的密钥完成

加密：

$$X \rightarrow Y : Y = E_{K_U}(X)$$

解密：

$$Y \rightarrow X : X = D_{K_R}(Y) = D_{K_R}(E_{K_U}(X))$$

6. 消息鉴别码

消息鉴别码

在网络通信中，有一些针对消息内容的攻击方法：

- 伪造消息
- 篡改消息内容
- 改变消息顺序
- 消息重放或者延迟

消息认证：

- 对收到的消息进行验证，证明确实是来自声称的发送方，并且没有被修改过。
- 如果在消息中加入时间及顺序信息，则可以完成对时间和顺序的鉴别。

消息鉴别的三种方式

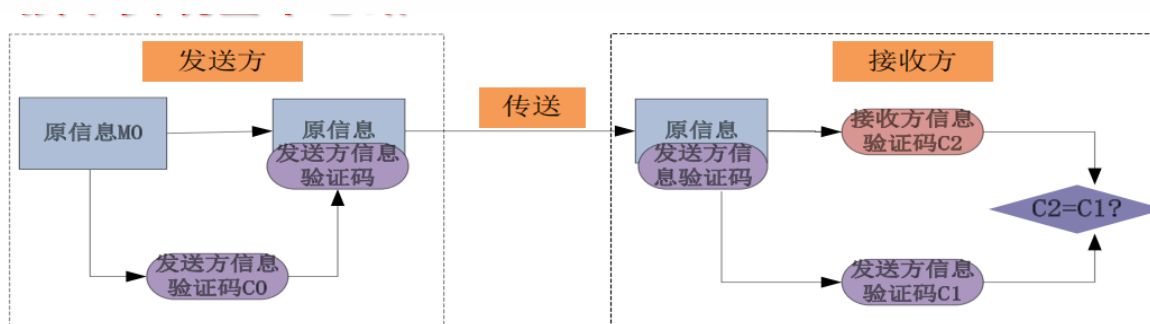
1. Message encryption:

- 用整个消息的密文作为鉴别标识。
- 接收方必须能够识别错误。

2. Hash function: 一个公开函数将任意长度的消息映射到一个固定长度的散列值，作为鉴别标识。

3. MAC: 一个公开函数，加上一个密钥产生一个固定长度的值作为鉴别标识。

技术实现基本思路



增加信息验证码对数据完整性进行验证

1. 发送方根据要发送的原信息 M0，利用验证码函数产生与 M0 密切相关的信息验证码 C0；
2. 发送方把原始信息 M0 和信息验证码 C0 合在一起，并通过网络发送给接收方；
3. 接收方对收到的信息和验证码进行分离，假设分别为 M1 和 C1，因为这两个信息可能已被篡改；
4. 接收方使用与原始信息相同的信息验证码函数（双方事先约定好的）对收到的信息部分计算出自己的信息验证码 C2；
5. 接收方将自己制作的验证码 C2 和分离出来的信息验证码 C1 进行对比：

- 如果 C_2 与 C_1 相等，接收方认为发送的信息 M_0 是相同的；
- 如果不相等，接收方知道原始信息已经被篡改。

CH5 鉴别机制与技术

对身份鉴别系统的要求

1. 验证者正确识别合法申请者的概率极大化。
2. 不具有可传递性 (Transferability)。
3. 攻击者伪装成申请者欺骗验证者成功的概率要小到可以忽略的程度。
4. 计算有效性。
5. 通信有效性。
6. 秘密参数能安全存储。
7. 交互识别。
8. 第三方的实时参与。
9. 第三方的可信赖性。
10. 可证明的安全性。

5.3 鉴别技术分类

- 0 级鉴别 (无保护)
- 1 级鉴别 (抗泄露保护)
- 2 级鉴别 (抗泄露和对不同验证者重放的保护)
- 3 级鉴别 (抗泄露和对同一验证者重放的保护)
- 4 级鉴别 (抗泄露和对相同/不同验证者重放的保护)

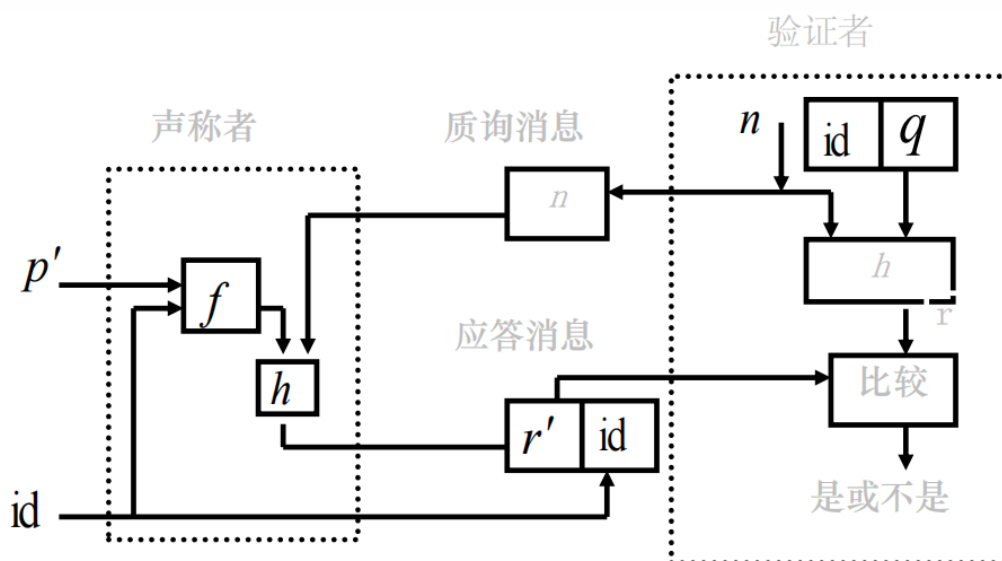
实现身份鉴别的途径

设计依据：安全水平、系统通过率、用户可接受性、成本等。

方式：

- 基于你所知道的 (What you know): 知识、口令、密码。
- 基于你所拥有的 (What you have): 身份证、信用卡、钥匙、智能卡、令牌等。
- 基于你的个人特征 (What you are): 指纹、笔迹、声音、手型、脸型、视网膜、虹膜。
- 双因素、多因素认证。

基于质询-应答的身份鉴别技术



- 验证者给声称者发送一个确定的值 (质询消息)，该值参与鉴别信息的运算。
- 产生的非重复质询消息完全由验证者决定，使得每次传输的鉴别信息不同。
- 能很好地防止口令窃听和重放，但需要额外的通信开销

- 优点
 - 防止口令窃听和重放。
 - 产生非重复值的能力完全掌握在验证者手中。提供了一种很好的重放检测能力。
 - 附加的复杂协议意味着这种机制不能与传统的简单口令协议结合使用。

质询—响应的身份鉴别，其安全性取决于

- 散列函数的安全性；
- 由于是单向鉴别，还存在着验证者的假冒和重放攻击。

这可以通过双向鉴别或时间戳来解决。

质询/应答方式 (Challenge/Response)

- 流程
 1. A 期望从 B 获得一个消息。
 2. 首先发送给 B 一个随机值 (challenge)。
 3. B 收到这个值之后，对它作某种变换，并返回给 A。
 4. A 收到 B 的 response，期望包含这个随机值。
- 局限性
 - 不适用于非连接性的应用，因为要求在传输开始之前先有握手的额外开销

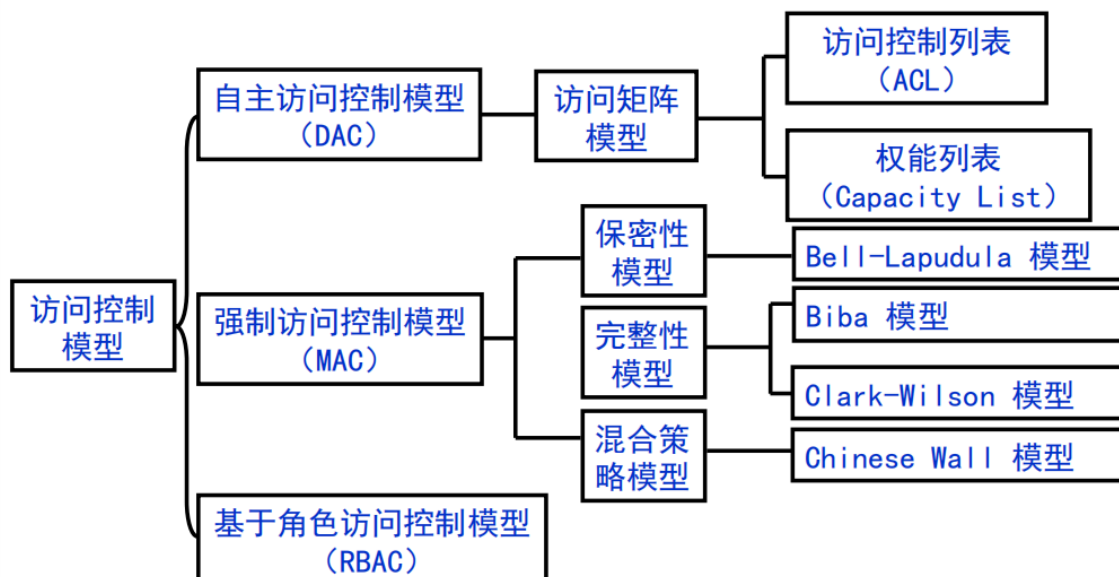
CH6 访问控制机制与技术

1. 访问控制的概念与模型分类

- **概念：** 访问控制是指对越权使用资源的防御措施
- **目标：** 防止对任何资源（如计算资源、通信资源 **网络安全设备** 或信息资源）进行未授权的访问，从而使资源在授权范围内使用，决定用户能做什么，也决定代表一定用户利益的程序能做什么。

2. 访问控制模型的分（ 主观感觉会考）

可以直接回答：DAC、MAC和RBAC



3. 自主访问控制模型的定义Discretionary Access Control , DAC

- DAC 是一种分布式授权管理模式。
- 允许客体的属主（创建者）决定主体对该客体的访问权限
 - 灵活地调整安全策略
 - 具有较好的易用性和可扩展性
 - 常用于商业系统
 - 安全性不高

自主访问控制 (DAC) 的特点

- 优点：
 - 根据主体的身份和访问权限进行决策
 - 具有某种访问能力的主体能够自主地将访问权的某 个子集授予其它主体 灵
 - 活性高，被大量采用
- 缺点：信息在传递过程中其访问权限关系会被改变

4. 强制访问控制的含义（!!! 主观感觉必考!! 务必背下所有内容）

Mandatory Access Control, MAC

- 主体对客体的所有访问请求按照**强制访问控制策略**进行控制，客体的属主无权控制客体的访问权限，以防止对信息的非法和越权访问。
 - 主体和客体分配有一个安全属性。
 - 应用于军事等安全要求较高的系统。
 - 可与自主访问控制结合使用。

强制型访问控制（MAC）

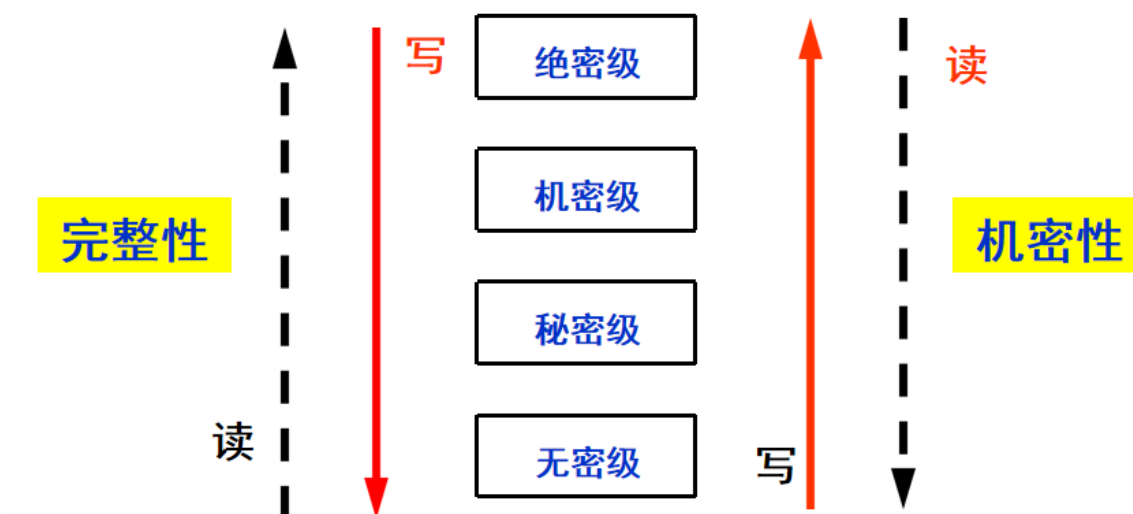
特点：

- 将主体和客体分级，根据主体和客体的级别标记来决定访问模式。
- 其访问控制关系分为：**上读/下写，下读/上写**。
- 通过梯度安全标签实现单向信息流通模式。

四种强制访问控制策略规定：

- **下读**：用户级别大于文件级别的读操作。
- **上写**：用户级别低于文件级别的写操作。
- **下写**：用户级别大于文件级别的写操作。
- **上读**：用户级别低于文件级别的读操作。

MAC 中主体对客体的访问有四种方式



强制访问控制——下读/上写（选择题判断是机密性还是完整性）

- 向下读（Read Down, rd）
 - 主体高于客体时允许读；
 - 低级别用户不能读高敏感度的信息。
- 向上写（Write Up, wr）
 - 主体低于客体时允许写；
 - 不允许高敏感度的信息写入低敏感度区域。
- 信息流只能从低级别流向高级别，从而保证**数据机密性**。

强制访问控制——上读/下写（选择题判断是机密性还是完整性）

- 向上读（Read Up, ru）
 - 主体低于客体时允许读操作。
 - 低信任级别的用户能够读高敏感度的信息。
- 向下写（Write Down, wd）
 - 主体高于客体时允许写操作。
 - 允许高敏感度的信息写入低敏感区域。
- 实现**数据完整性**。

常见强制访问控制模型

1. BLP模型

- 1973年提出的多级安全模型，影响了许多其他模型的发展。
- 对计算机安全技术的发展有很大影响。

2. Biba模型

- 1977年提出，关注完整性保护，与 BLP 模型对偶。

3. Clark-Wilson 模型

- 1987年提出，以事物处理为基础的完整性模型，应用于多种商业系统。

4. Chinese Wall 模型

- 1989年提出，解决商业中利益冲突问题的模型。

Bell-LaPadula (BLP) 模型

- 下读/上写
- 保证机密性



总结：RBAC 模型的特点 (!!! 背!!!)

1. 便于授权管理：系统管理员需要修改系统设置等内容时，必须有几个不同角色的用户到场方能操作，增强了安全性
2. 便于处理工作分级：如文件等资源分级管理。
3. 利用安全约束：实现最小特权、职责分离等安全策略。
4. 便于任务分担：不同角色完成不同的任务。

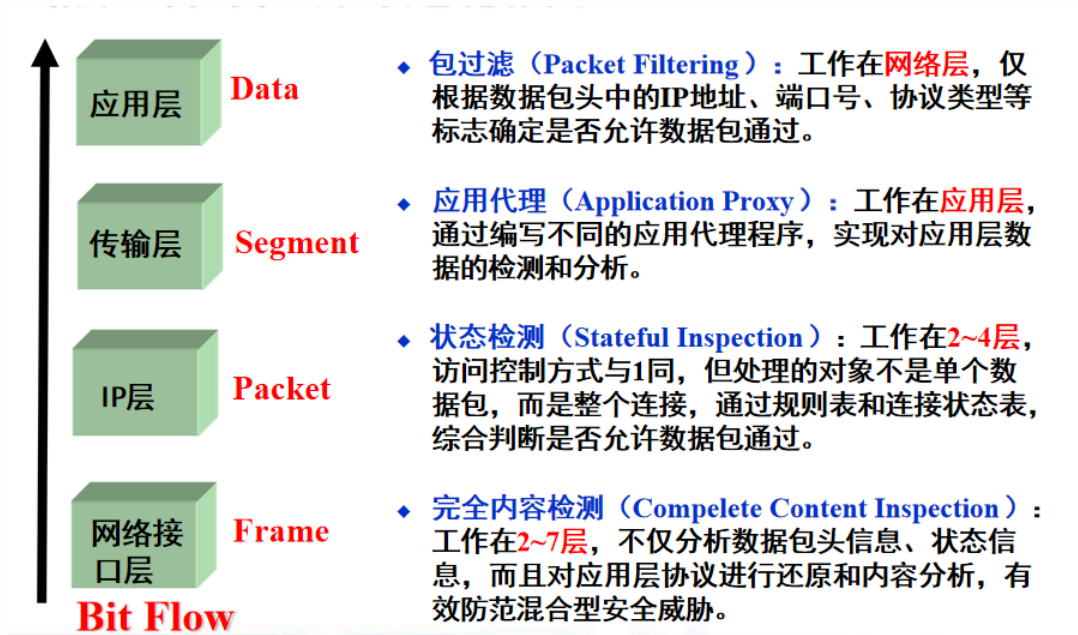
CH7 防火墙技术及其发展（看一下switch的内容）

1. 防火墙的基本概念

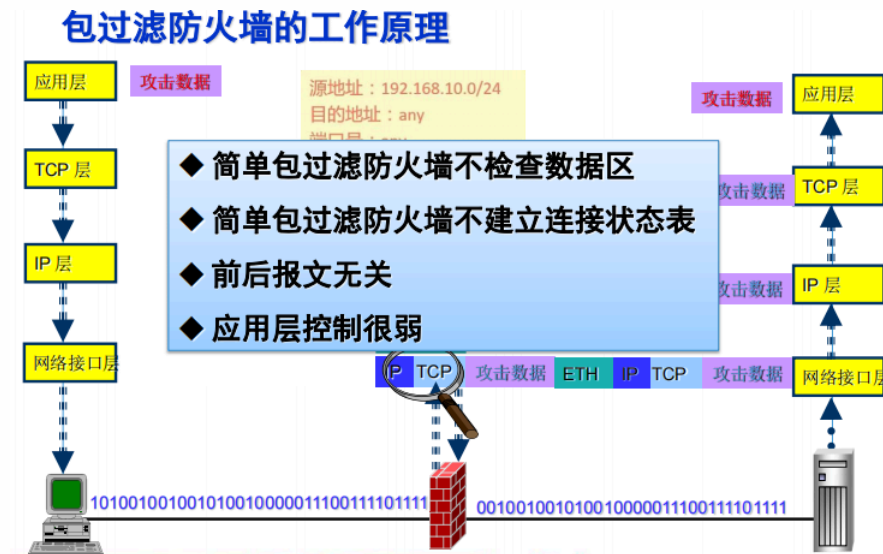
防火墙 (Firewall) 定义：

- 在网络间（内部/外部网络、不同信息级别）提供**安全连接**的设备；
- 用于**实现和执行网络之间通信的安全策略**。

2. 防火墙的检测与过滤技术



包过滤防火墙的工作原理



包过滤技术 (Packet Filter)

包过滤防火墙的特点:

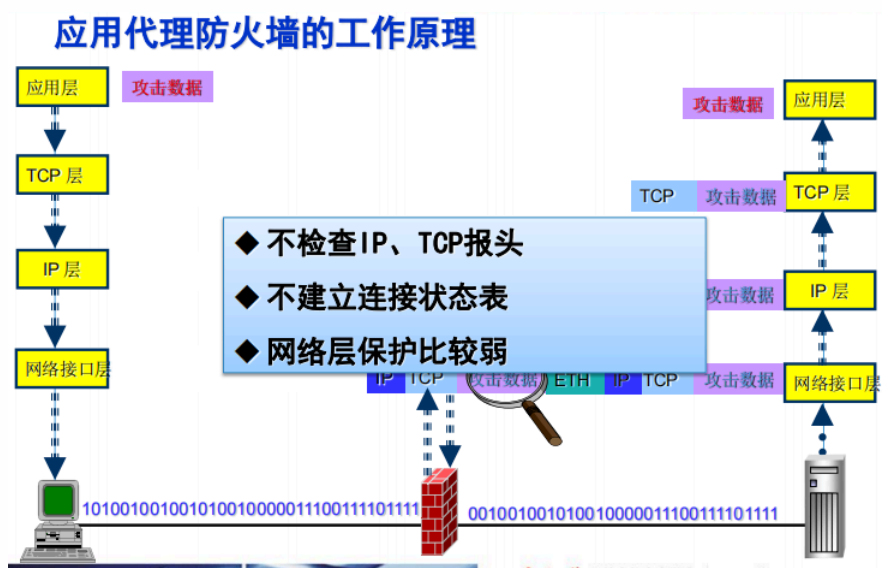
1. 优点:

- 只对数据包的 IP 地址、TCP/UDP 协议和端口进行分析, 规则简单, 处理速度较快。
- 易于配置。
- 对用户透明, 用户访问时不需要提供额外的密码或使用特殊的命令。

2. 缺点:

- 检查和过滤器只在网络层, 不能识别应用层协议或维持连接状态。
- 安全性薄弱, 不能防止 IP 欺骗等。
- 静态策略可能成为漏洞。

应用代理防火墙的工作原理



应用网关或代理 (Application Gateway or Proxy)

应用代理型网关防火墙具有以下特点：

优点：

- 可以检查应用层、传输层和网络层的协议特征，对数据包的检测能力比较强。
- 提供良好的安全性：所有数据的有效负载都在应用层进行检查。

缺点：

- 支持的应用数量有限，无法很好地支持新的应用、技术和协议。
- 对用户不透明。
- 性能表现欠佳。

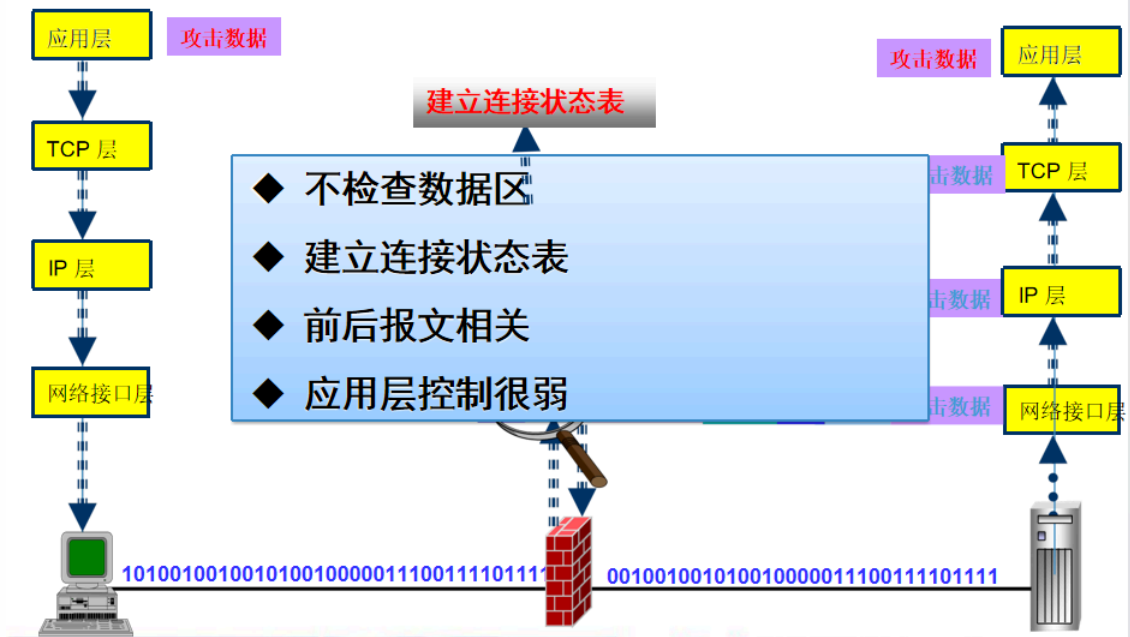
补充说明：自适应代理技术的出现让应用代理防火墙技术出现了新的转机。它结合了代理防火墙的安全性和包过滤防火墙的高速优势，在不损失安全性的基础上大大提高了代理防火墙的性能。

状态检测防火墙 (Stateful Inspection)

- 内置 TCP/IP 协议状态机，创建状态表用于维护连接上下文，检查每个会话连接的合法性（是否符合 TCP/IP 通信原理和特征）。
- 能够识别和监听常用动态端口应用的协议过程，从而自动为动态应用建立通过防火墙的安全连接。

状态检测防火墙摒弃了包过滤防火墙仅考查数据包的 IP 地址等几个参数，而不关心数据包连接状态变化的缺点，在防火墙的核心部分建立状态连接表，并将进出网络的数据当成一个个的会话，利用状态表跟踪每一个会话状态。状态监测对每一个包的检查不仅根据规则表，更考虑了数据包是否符合会话所处的状态，因此提供了完整的对传输 层的控制能力。

状态检测防火墙的工作原理

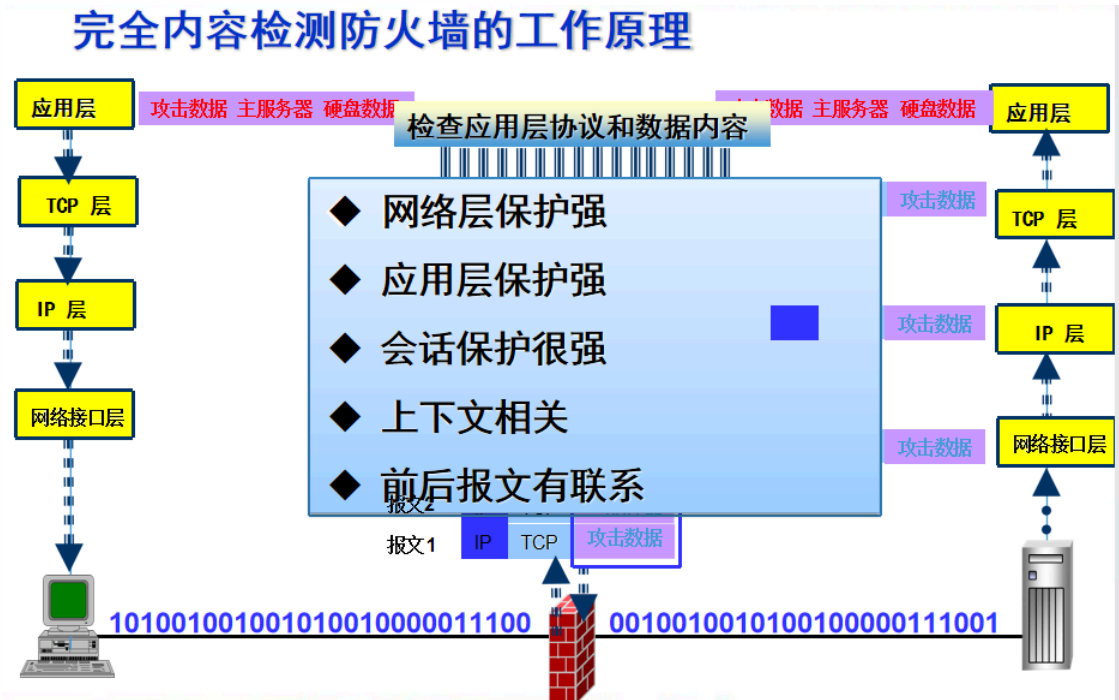


特点

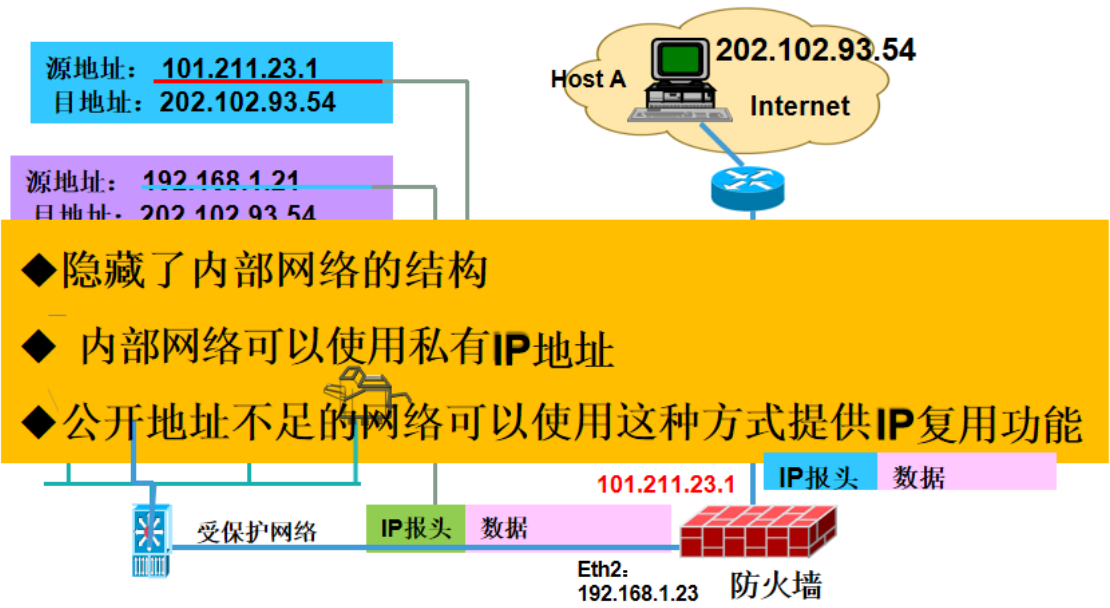
- 性能大大提高。
- 支持大量应用。
- 在内核级实现检测过滤：
 - 在所有接口对进/出的数据包进行状态检查。
- 支持应用层协议检查：
 - 在动态状态表中存储连接状态。
 - 检查对外的连接并预先计算出将返回的连接。

状态检测技术在大为提高安全防范能力的同时，也改进了流量处理速度。**状态监测技术采用了一系列优化技术，使防火墙性能大幅度提升**，能应用在各类网络环境中，尤其是在一些规则复杂的大型网络上。

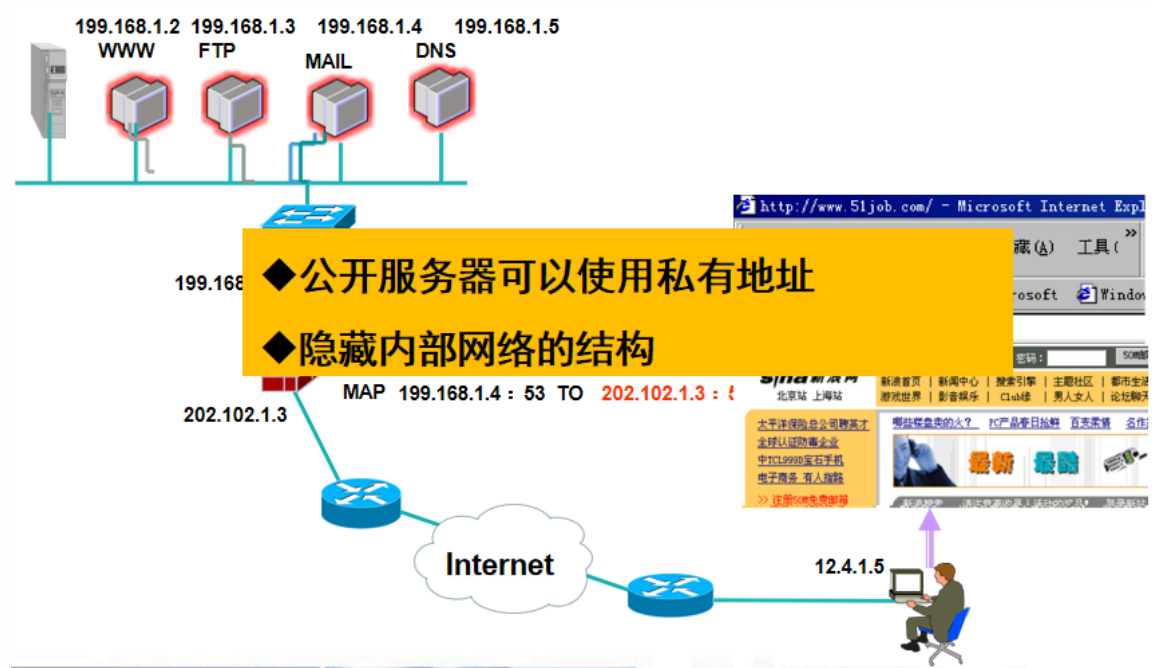
从 2000 年开始，国内的著名防火墙公司都开始采用这一新的体系架构。



3. 地址转换 (NAT) (3-5好好看看)



4. MAP (地址/端口映射)



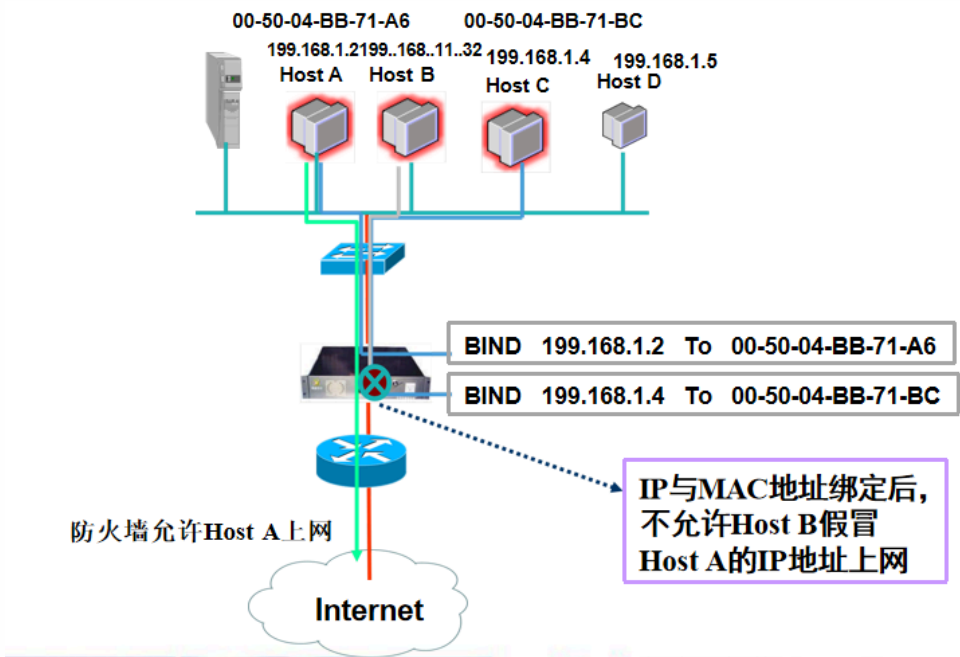
1. 功能:

- 将内部网络中的私有IP地址 (如 199.168.1.x) 映射为公网IP地址 (如 202.102.1.3), 从而使内部设备能够与外部网络 (如Internet) 通信。
- 将外部对特定服务 (如 DNS、FTP、WWW) 的访问请求重定向到内部私有网络中的对应服务器。

2. 主要目的:

- **公用服务器使用私有地址:** 内部服务器可以通过地址/端口映射被外部访问, 而不需要直接暴露私有IP地址。
- **隐藏内部网络结构:** 外部设备无法直接查看内部网络的拓扑结构, 从而提高安全性。

5. IP与MAC (用户) 绑定



6. 防火墙的工作接入方式

- 路由接入
- 透明接入
- 混合接入

7. 衡量防火墙性能的五大指标

1. **吞吐量**：该指标直接影响网络的性能，吞吐量指防火墙在单位时间内能处理的数据量。
2. **时延**：入口处输入帧最后一个比特到达至出口处输出帧的第一个比特开始输出所用的时间间隔。
3. **丢包率**：在稳态负载下，应用网络设备传输，但由于资源缺乏而被丢弃的帧的百分比。
4. **背靠背**：从空闲状态开始，以达到传输介质最小合法间隔极限的传输速率发送相当数量的固定长度的帧，当出现第一个帧丢失时，发送的帧数。
5. **并发连接数**：并发连接数是指穿越防火墙的主机之间或主机与防火墙之间能同时建立的最大连接数。

CH8 入侵检测

1. 什么是入侵

入侵（Intrusion）是指在非法或未经授权的情况下，试图存取或处理系统或网络中的信息，或破坏系统或网络正常运行，致使系统或网络的机密性、完整性和可用性受到破坏的故意行为。

2. 入侵检测模型

- 通用入侵检测模型 (Denning 模型)
- 层次化入侵检测模型 (IDM)
- 管理式入侵检测模型 (SNMP-IDSM)

3. IDS 分析技术分类

1. **异常检测**：通过采集和统计来发现网络或系统中可能出现的异常行为，向管理员提出警告。
2. **特征检测**：通过对采集的信息按已知的知识进行分析，来发现正在发生和已经发生的入侵行为。

!!! 记住下方表格， 感觉会考，感觉是判断类别

分析策略	特征检测	异常检测
缺省即允许	基于信号的特征检测	基于机器学习的异常检测
缺省即禁止	基于策略的特征检测	基于轮廓的异常检测

4. 异常检测 (Anomaly Detection)

- 也称为基于行为的检测。
- 首先建立起用户的正常使用模式，即知识库。
- 标识出不符合正常模式的行为活动。
- 假设所有的入侵行为是异常的；

- 基于系统和基于用户的异常。
- 比较符合安全的概念，但实现难度较大：
 - 正常模式的知识库难以建立。
 - 难以明确划分正常模式和异常模式。

5. 特征检测 (Misuse Detection)

- 也称为误用检测：
- 是针对已知（类似）的攻击行为和间接的违反系统安全策略行为的检测，攻击和系统漏洞库是特征检测的基础。
- 特点
 - 建立入侵行为模型（攻击特征库）。
 - 判断当前行为活动是否符合已知的攻击模式。
 - 假设可以识别和表示所有可能的特征。
 - 基于系统的和基于用户的。
 - 目前研究工作比较多，并且已经进入实用。

优点：

- 准确率高；
- 算法简单。

关键问题：

- 所有的攻击特征，建立完整的特征库；
- 特征库要不断更新（动态性）；
- 无法检测新的入侵。

数据来源：

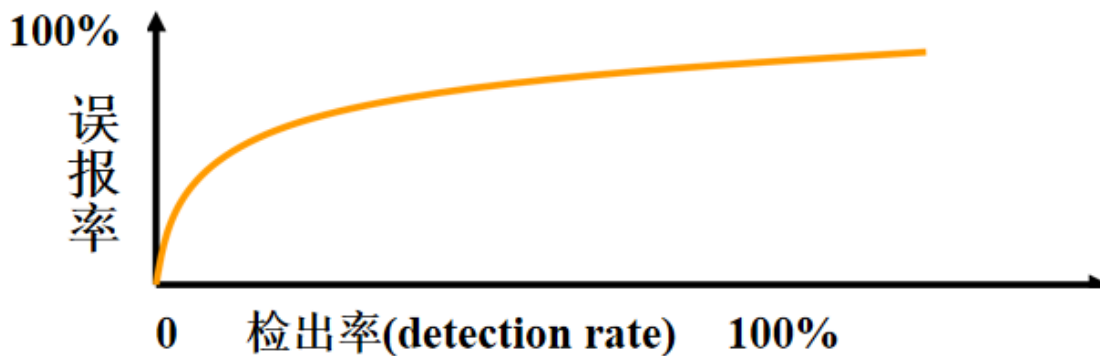
- 审计日志或网络流量；
- 特殊用途的数据收集机制。

6. IDS 的两个指标

1. **漏报率 (False Negative)**：指攻击事件没有被 IDS 检测到。
2. **误报率 (False Alarm Rate)**：把正常事件识别为攻击并报警。

误报率与检测率关系：

- 随着检测率（Detection Rate）提高，误报率（False Alarm Rate）成正比例关系上升。



CH9 其他网络安全技术及设备（fy：网闸很重要）

◆安全隔离与信息交换系统（网闸）



1. 应对网络安全漏洞传统解决方案

- **中央文件：** 中央中央办公厅第十七号文件规定，“电子政务网络由政务内网和政务外网构成，两网之间**物理隔离**，政务外网与互联网之间逻辑隔离。”
- **国家保密局规定：** 《计算机信息系统国际联网保密管理规定》第六条规定：“涉及国家秘密的计算机信息系统，不得直接或间接地与国际互联网或其他公共信息相连接，**必须实行物理隔离。**”
- **部分组织实践：** 一些组织根据自身业务特点，在有不同安全需求的网络之间也采用了**物理隔离**的措施。

物理隔离的核心思想是不连接，没有连接！

2. 物理隔离带来的问题

- 物理隔离使得正常的信息交流被阻断。
- 部分重要的与业务相关的数据需要在涉密网络和非涉密网络之间交换，但由于物理隔离无法实现。
- 物理隔离也成为电子政务、电子商务的数据传输应用的瓶颈。

3. 传统物理隔离的应用解决方案分析

优点： 保持了网络间物理隔离的特性，有效防止了对涉密网络的直接网络攻击。

缺点：

- 延时长；
- 速度慢；
- 应用过于单一；
- 可靠性低；
- 在防病毒、内容过滤等方面效果较差；
- 存在人工操作风险。

4. 什么是网闸

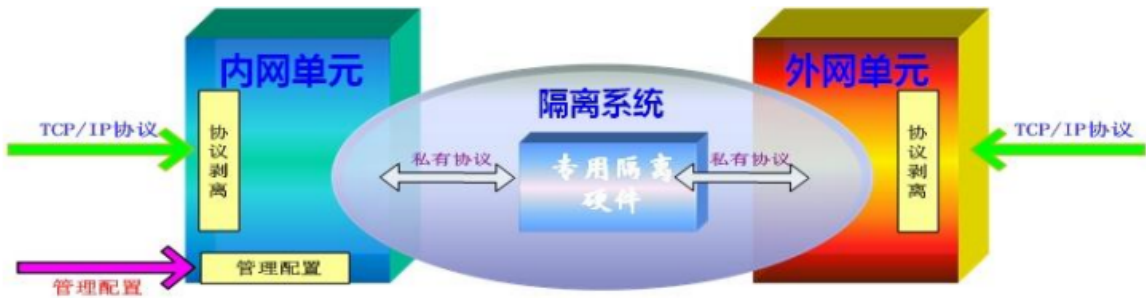
网闸是在**两个不同安全域之间**，通过协议转换的手段，以信息摆渡的方式实现数据交换，且只有被系统明确要求传 输的信息才可以通过。其信息流一般为通用应用服务。

在信息摆渡的过程中内外网（上下游）通过策略控制连接发生，所以“网闸产品”必须要有至少两套主机和一个隔离部件才可完成物理隔离任务。

网闸主要用于在两个隔离程度高的网络之间进行**安全的数据交换**。

5. 安全隔离网闸组成

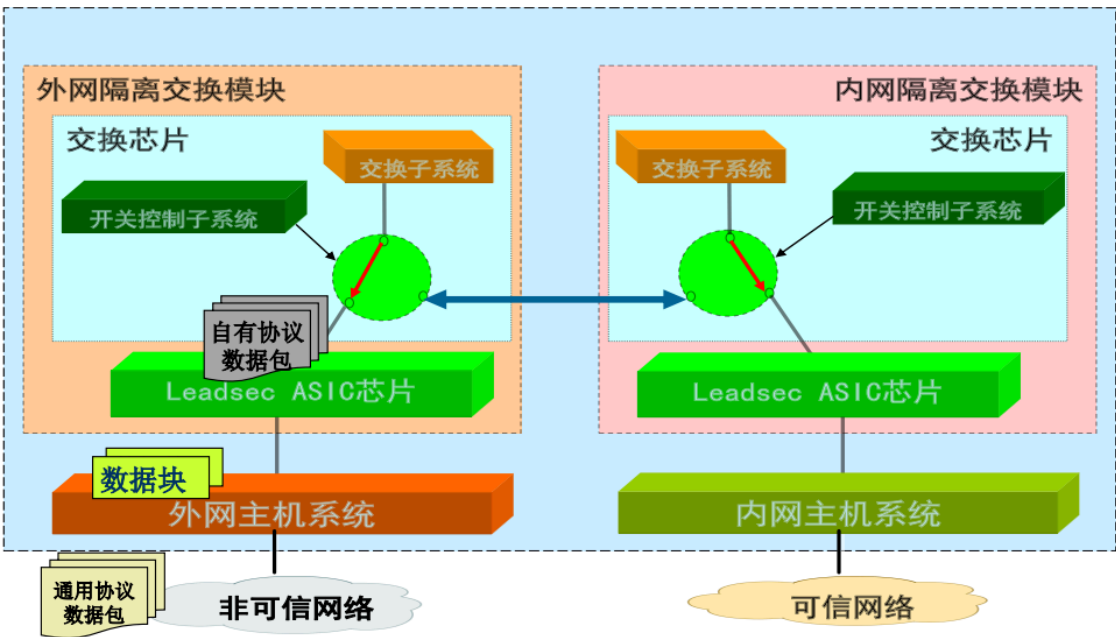
由内端机、外端机、隔离系统（也称数据迁移控制单元）三部分组成

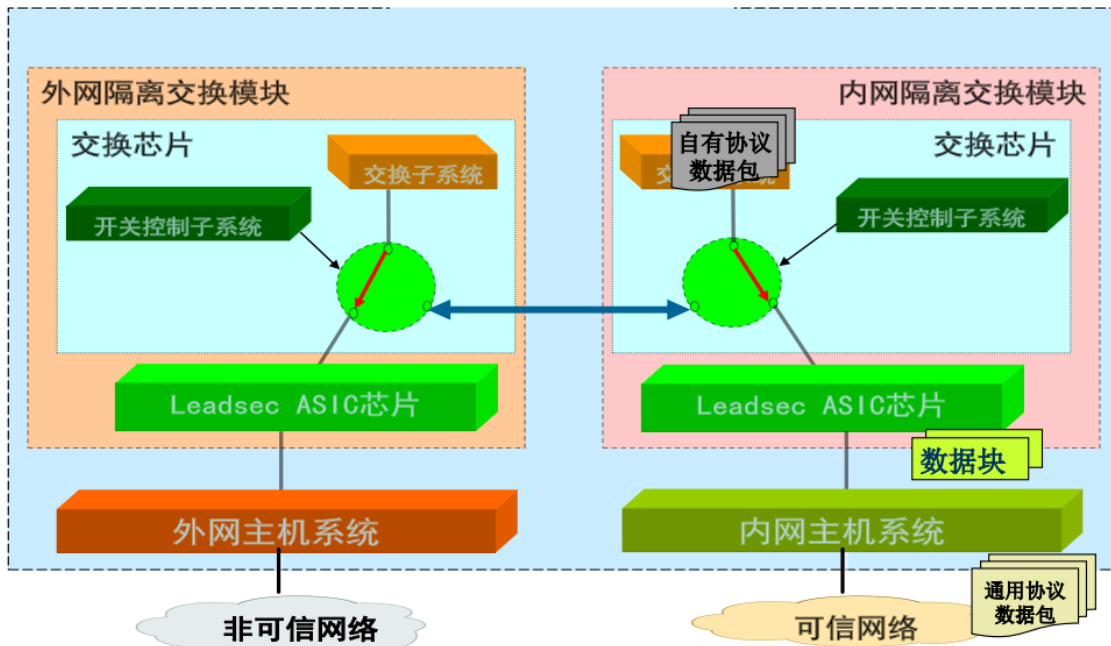
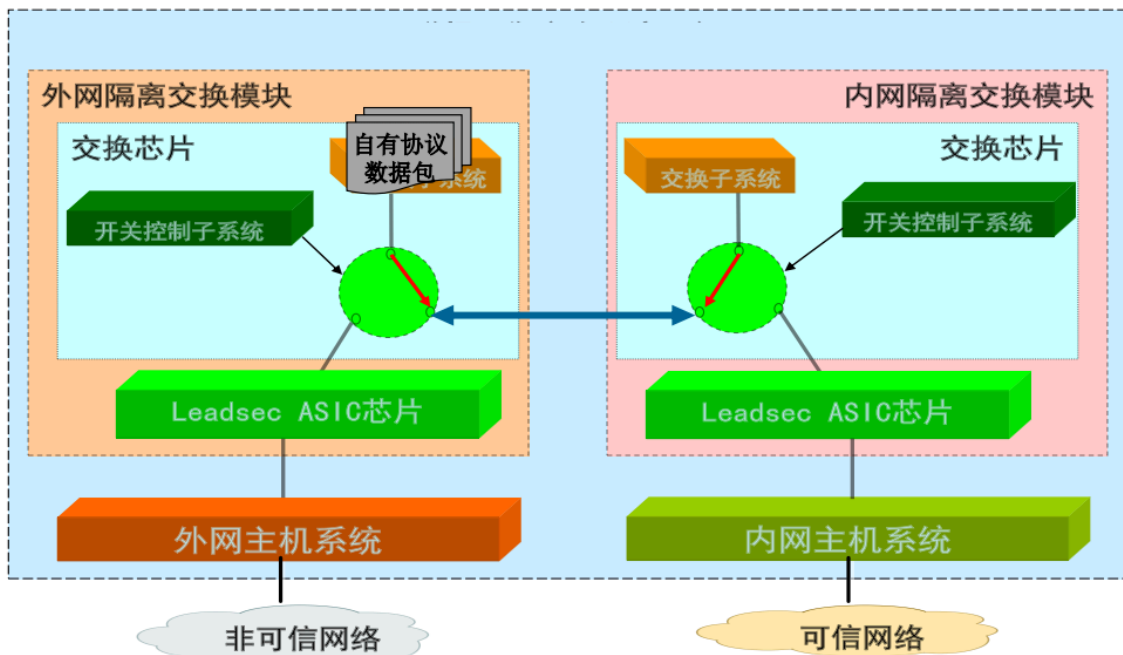


原理 通过网闸时，会切断两端的协议连接，将数据包分解为静态数据，然后对数据进行审查等操作，然后通过私有协议再流入内部单元

- 切断网络之间的通用协议连接；
- 将数据包进行分解或重组为静态数据
- 对静态数据进行安全审查，包括网络协议检查和代码扫描等；
- 确认后的安全数据流入内部单元。

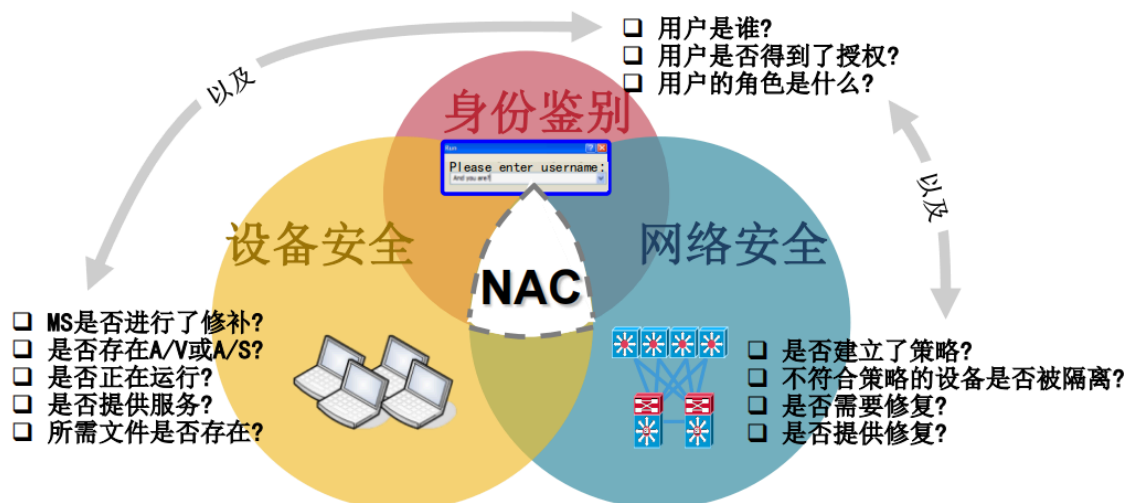
6. 数据隔离交换过程



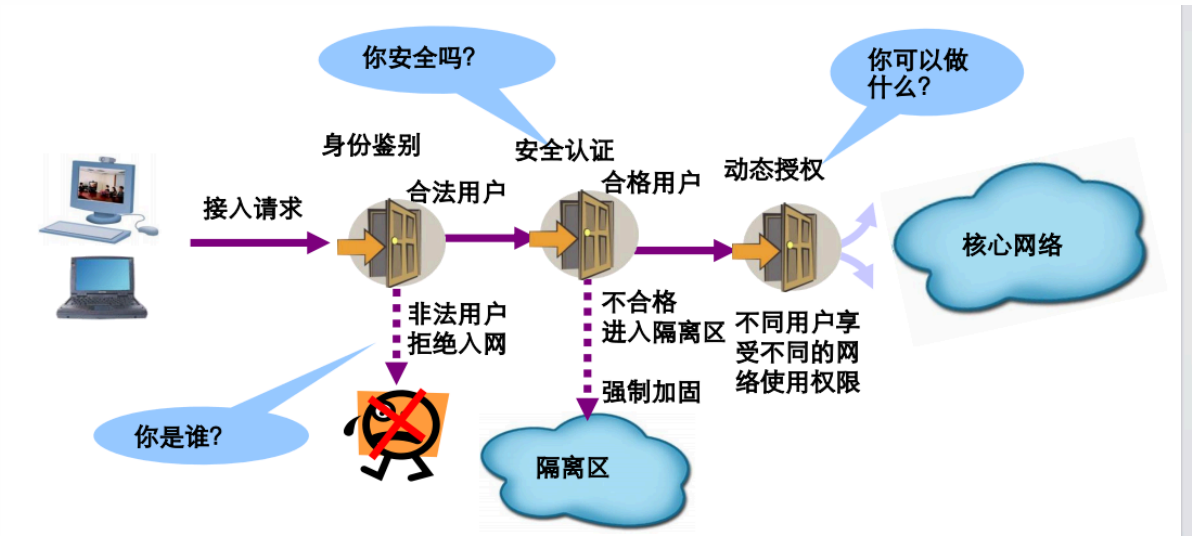


7. 什么是网络准入控制

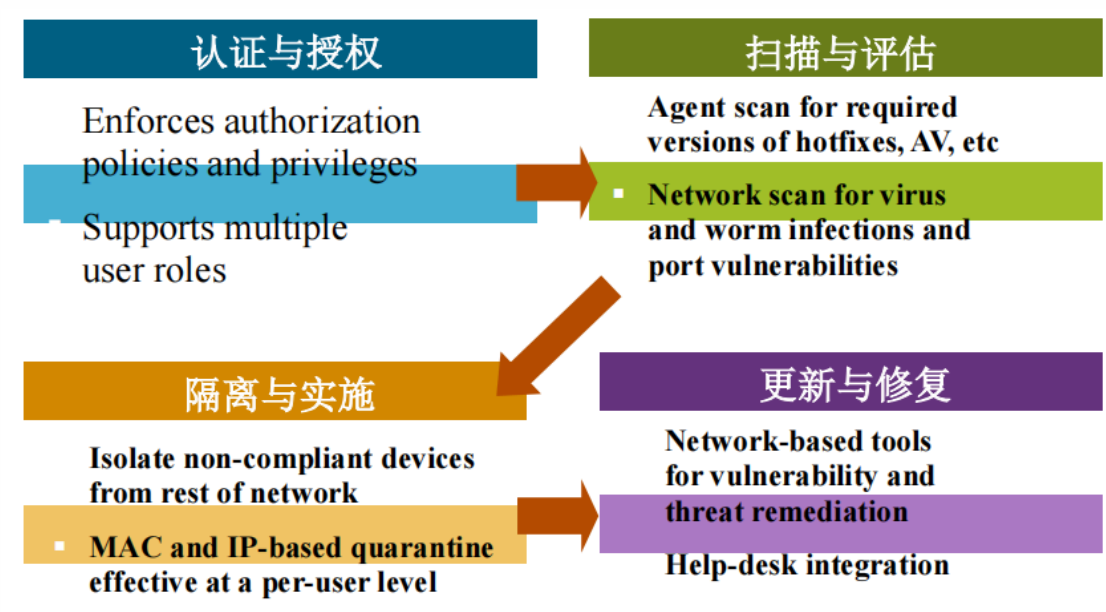
使用网络准入安全策略，确保进入网络的设备符合策略



网络准入控制系统的功能需求



8. NAC的主要功能



9. 什么是入侵防御系统

IPS是一种**集入侵检测和防御于一体**的安全产品，它不仅能检测入侵的发生，而且能通过一定的响应方式，实时地中止入侵行为的发生和发展，实时地保护信息系统不受实质性的攻击。**IPS使得IDS和防火墙走向统一**。简单地理解，可以为**IPS就是防火墙加上入侵检测系统**。

IPS主要功能

- 识别对网络和主机的恶意攻击，并实时进行阻断；
- 向管理控制台发送日志信息；
- 集成病毒过滤、带宽管理和URL过滤等功能；

部署方式对比（ ）

IPS	IDS
在线，流量必须通过IPS	旁路，通过镜像获得数据

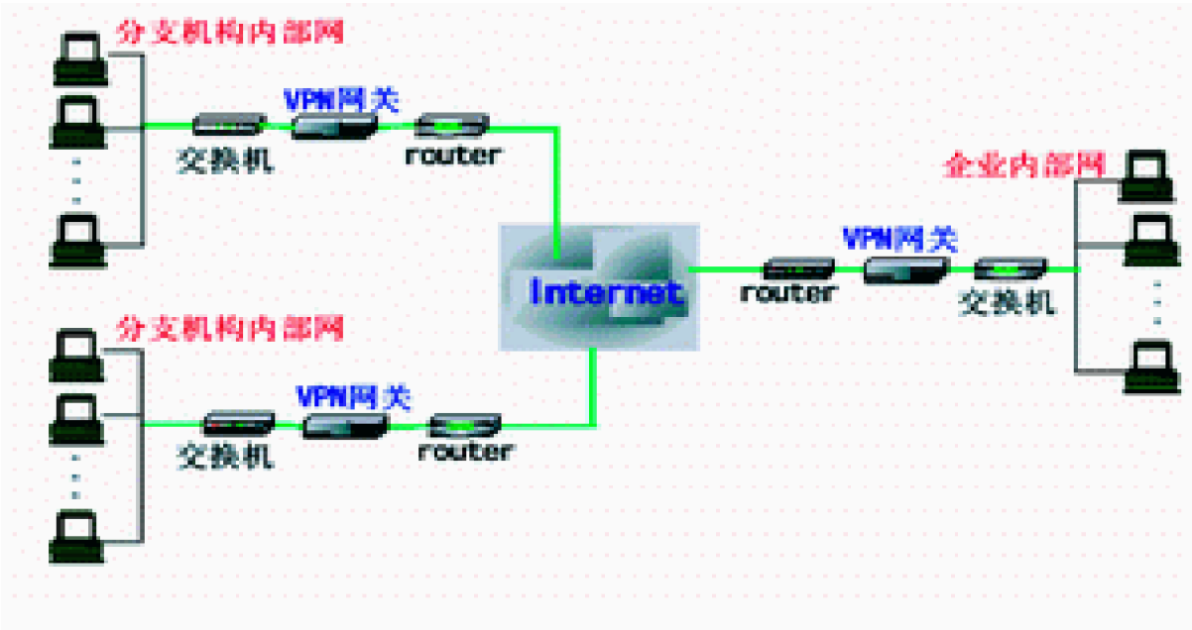
IPS	IDS
实时，其时延必须满足业务要求	准实时，可接受秒级时延
立刻影响网络报文	对网络及业务无直接影响
作用范围有限制	监控范围广

设计出发点对比

IPS	IDS
无误报	无漏报
满足峰值流量和时延要求	满足平均流量，可接受秒级时延
不能影响业务系统可用性	只需关注自身功能实现

CH10 虚拟专用网技术

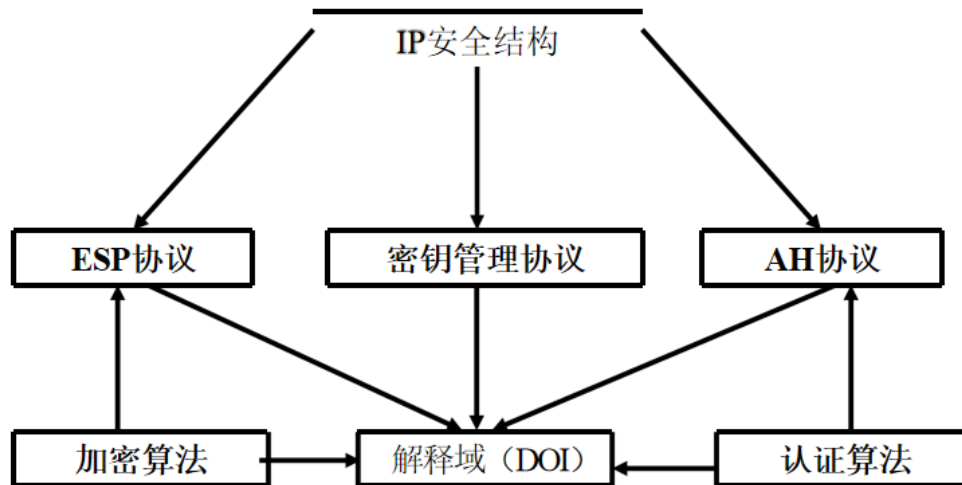
1. VPN概念



IPSec 协议实际上是一个协议包而不是一个单独的协议，主要是下面三个协议

- 认证头 (Authentication Header, AH)：用于数据完整性认证和数据源认证。
- 封装安全负荷 (Encapsulating Security Payload, ESP)：提供数据保密性和数据完整性认证，ESP 也包括了防止重放攻击的顺序号。
- Internet 密钥交换协议 (Internet Key Exchange, IKE)：用于生成和分发给 ESP 和 AH 中使用的密钥，IKE 也对远程系统进行初始认证。

2 IPSec协议体系

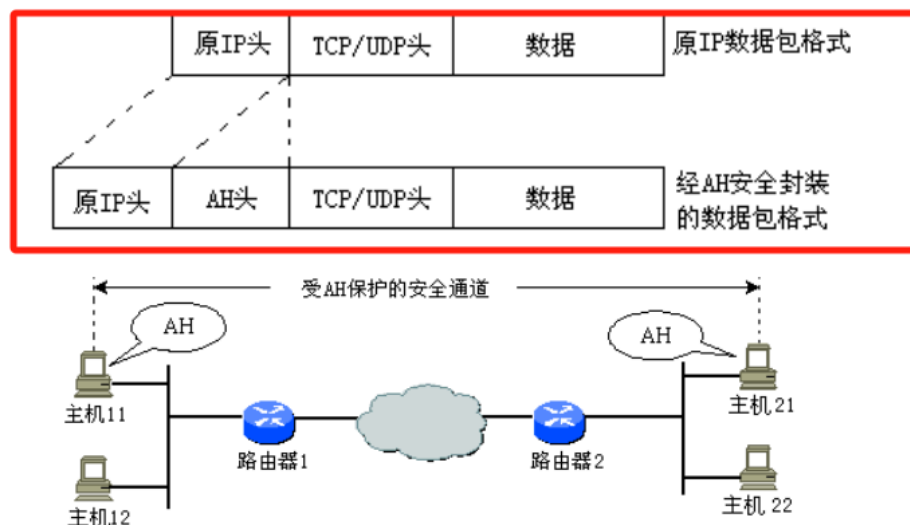


3. 鉴别头部 (AH)

提供了数据完整性和数据源认证，即用来保证传输的 IP 报文的来源可信和数据不被篡改，但它并不提供加密功能。

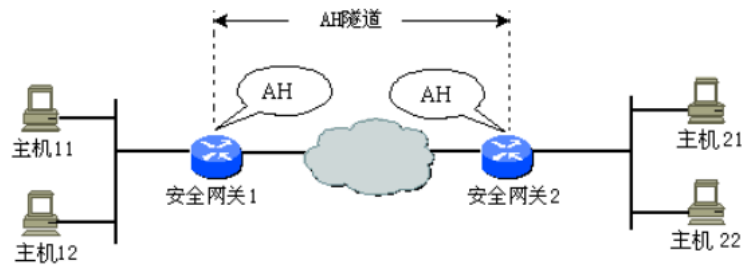
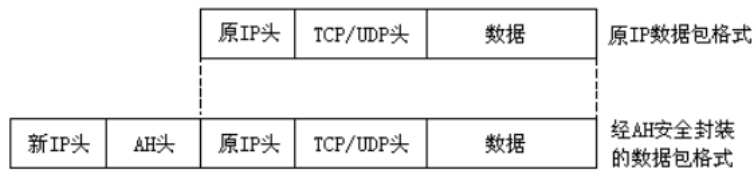
根据AH头插入IP包的位置不同，AH有**传输模式**和**隧道模式**两种工作模式

AH传输模式



AH隧道模式

AH的隧道模式将AH头插入原IP分组的IP头之前，并在AH头之前添加新的IP头，这个新的IP头的协议字段将是51，以表明IP头之后的是一个AH头



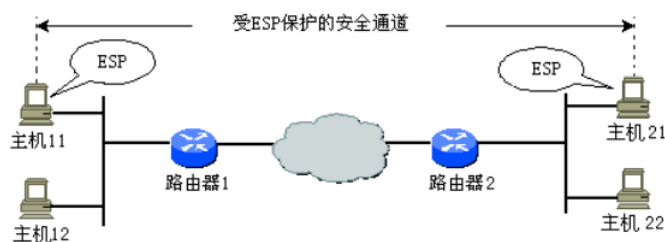
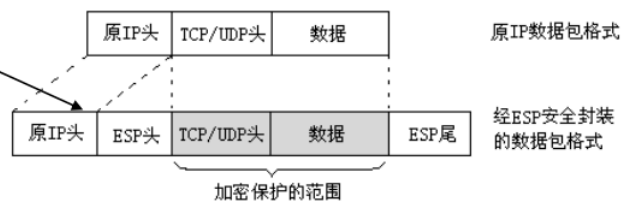
4. 负载安全封装 (ESP)

IPSec 封装安全负荷提供了数据加密功能。ESP 利用对称密钥对 IP 数据 (例如 TCP 包) 进行加密。由于 ESP 除具备 AH 的全部功能外还用于确保数据包的机密性, 因此每个 ESP 的 SA 都必须同时定义两套算法: 负责保护机密性的加密算法和负责进行身份验证的鉴别算法

根据ESP封装的载荷内容不同, ESP头可选用两种方式中的一种来应用于IP数据包, 即**传送模式或隧道模式**, 其间的差别决定了ESP保护的真正对象是什么

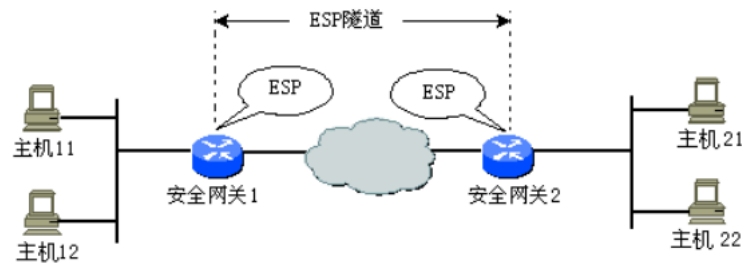
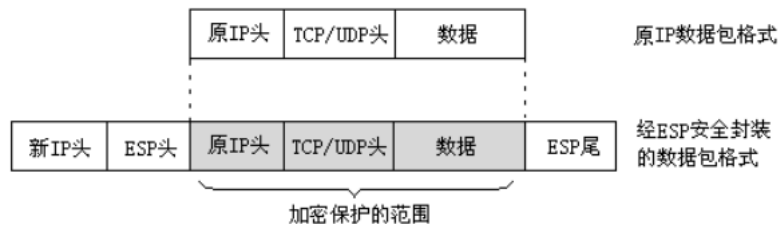
传输模式

IP头的协议字段由原来的值变为50



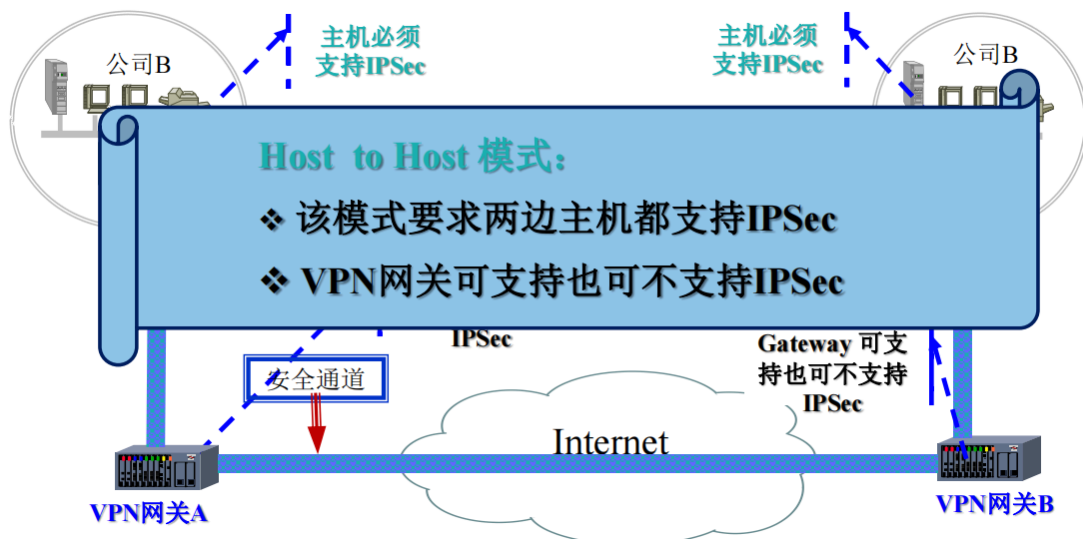
隧道模式

在隧道模式, 整个IP包 (包括原IP包头) 都被封装在ESP有效载荷中, 并产生一个新IP头附着在ESP头之前, 这个新的IP头的协议字段将是50, 以表明IP头之后的是一个ESP头

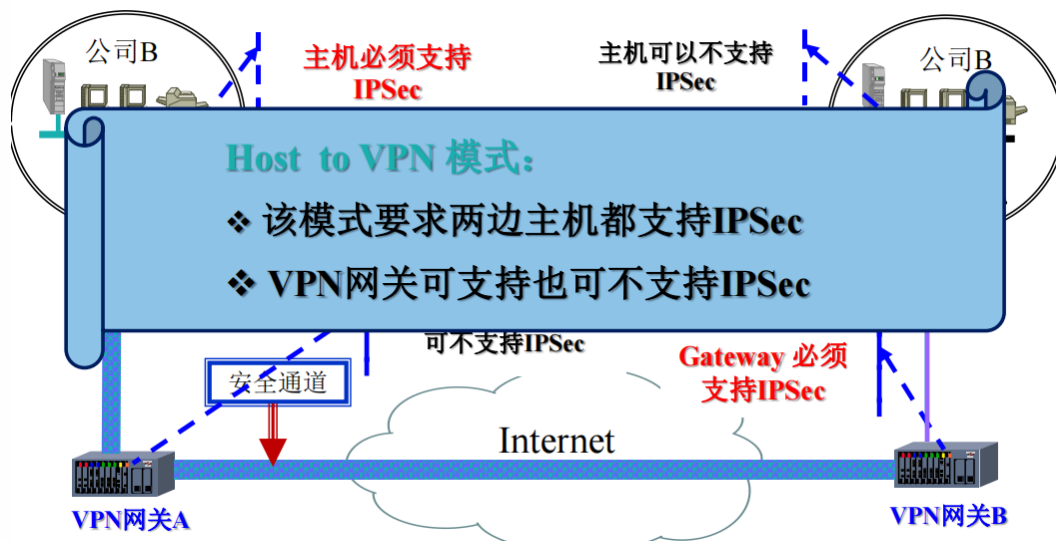


5. VPN通道的建立方式 (5.1-5.4可能会让画图，但是不太确定，建议看)

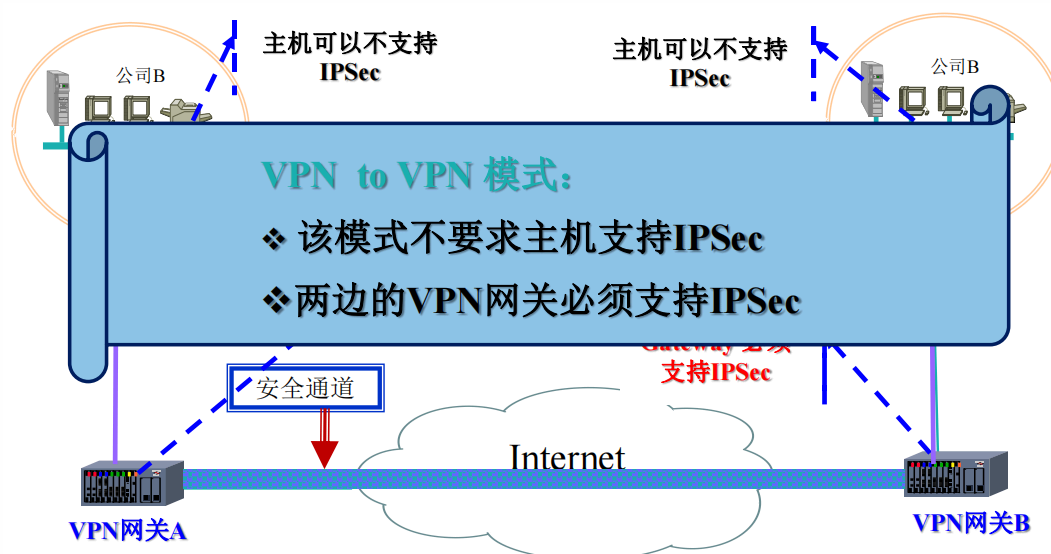
5.1 Host对Host



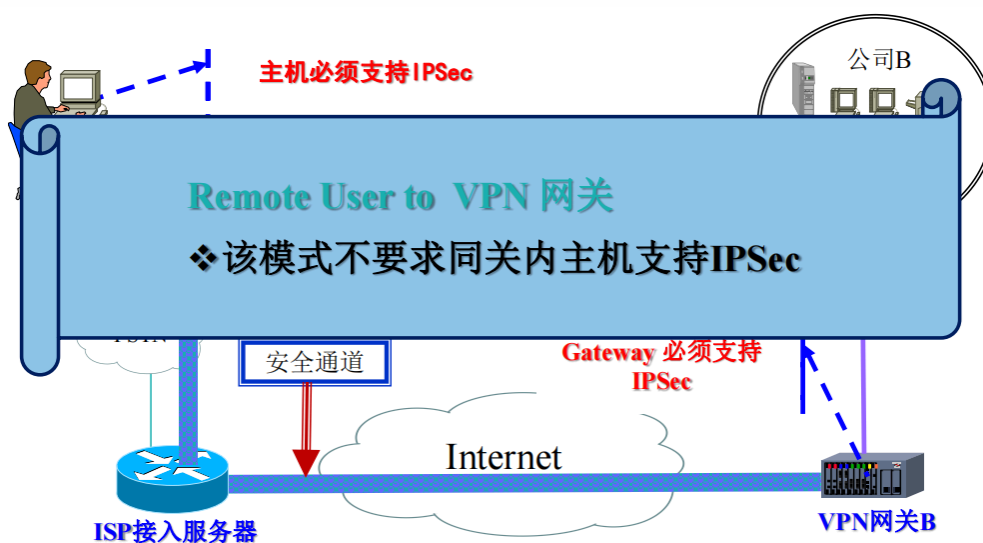
5.2 Host对VPN



5.3 VPN对VPN



5.4 Remote User to VPN

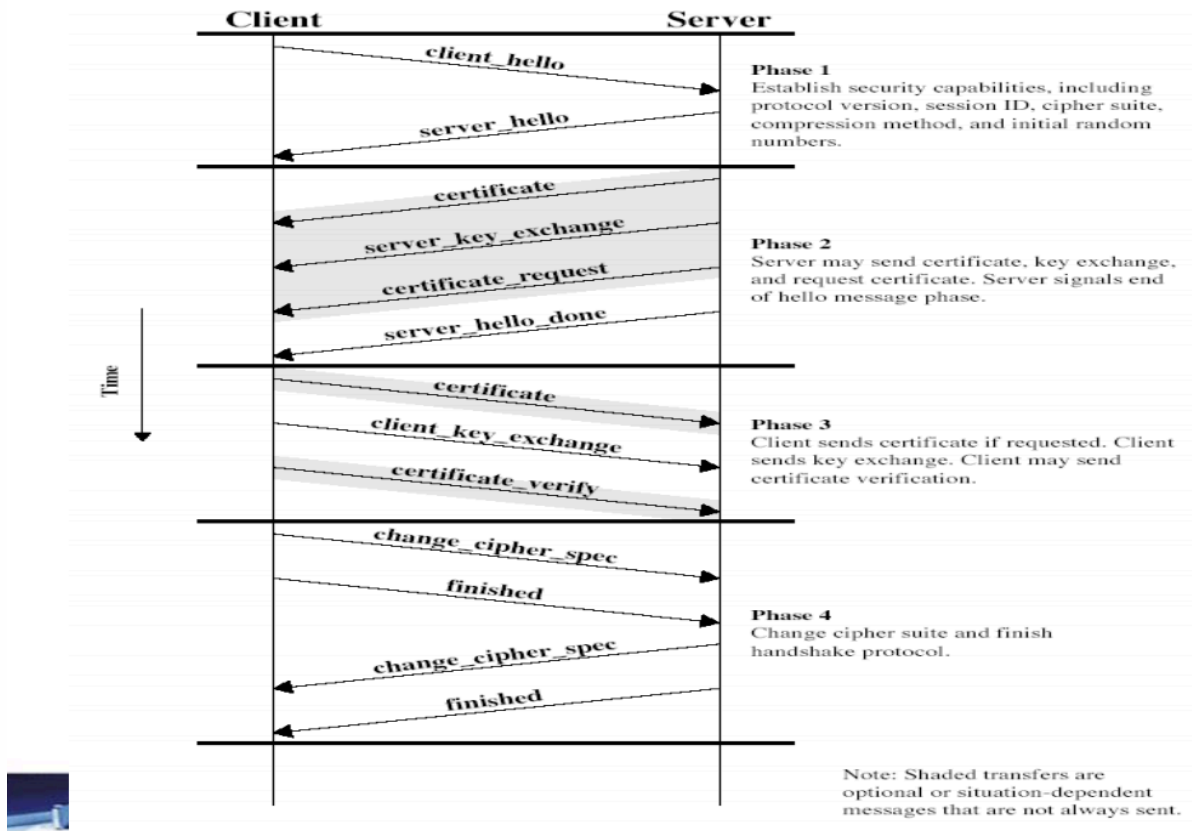


6. 传输层安全协议及其应用

SSL协议

- Secure Sockets Layer (安全套接层)
- 广泛地用于Web浏览器与服务器之间的身份认证和加密数据传输
- SSL协议提供的服务主要有：
 - 认证用户和服务器，确保数据发送到正确的客户机和服务器
 - 加密数据以防止数据中途被窃取
 - 维护数据的完整性，确保数据在传输过程中不被改变

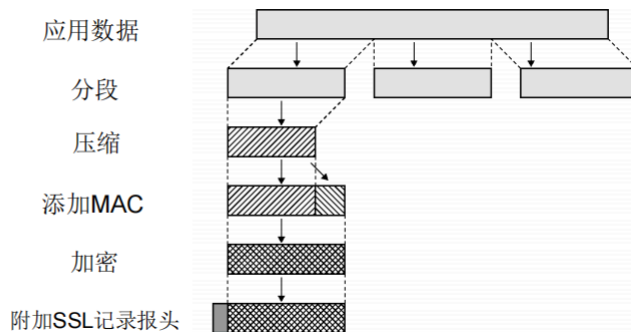
SSL握手协议行为过程（续）



SSL记录协议

❖ SSL记录协议。为SSL连接提供了两种服务

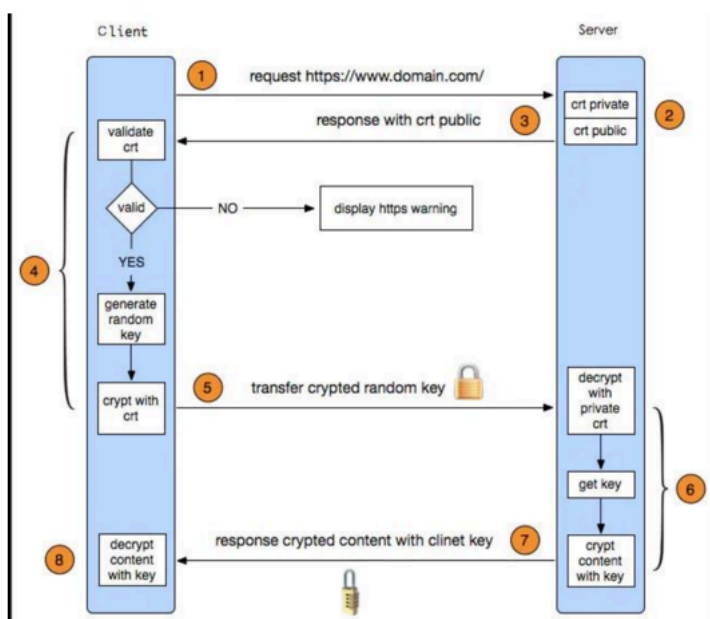
- **机密性**：握手协议为SSL有效载荷的常规密码定义共享秘密密钥。
- **消息完整性**：握手协议为生成MAC定义共享秘密密钥。
- ❖ 记录协议发出传输请求消息，把数据分段成可以操作的数据块，还可以选择压缩数据，加入MAC信息，加密，加入文件头，在TCP段中传输结果单元。接收到的数据需要解密、身份验证、解压、重组，然后才能交付



SSL应用实例——HTTPS

- HTTPS（全称：Hypertext Transfer Protocol over Secure Socket Layer），是HTTP的安全版。
- HTTPS的安全基础是SSL，通过结合HTTP和SSL来实现Web浏览器和Web服务器之间的安全通信。
- HTTPS已经融合在当今的Web浏览器中，只要Web服务器支持HTTPS，就可以使用。
- HTTPS现在已广泛用于Internet上的安全B/S应用，例如网上交易等
- HTTPS的规范文档可参阅RFC 2818（HTTPS Over TLS）

HTTPS通信过程（单向鉴别）



- 1、客户端向服务器发起连接请求
- 2、服务器生成公私钥对，通过可信机构对公钥等信息进行数字签名，形成服务器证书
- 3、服务器发送证书响应请求
- 4、客户端验证服务器证书，生成数据加密密钥，并采用服务器证书中的公钥对数据加密密钥进行保护
- 5、客户端向服务器发送加密后的数据加密密钥
- 6、服务器用私钥解密出数据加密密钥，并用该密钥加密要传输的静荷数据
- 7、客户端用数据加密密钥解密服务器传来的数据。

SSL安全性

❖ SSL标准协议存在着以下不容忽视的缺点

- 不符合《商用密码管理条例》中对商用密码产品不得使用国外密码算法的规定。
- 系统安全性还不够强。SSL协议的数据安全性其实就是建立在RSA等算法的安全性上，因此从本质上来讲，攻破RSA等算法就等同于攻破此协议。由于美国政府的出口限制，使得进入我国的实现了SSL的产品（Web浏览器和服务端）均只能提供512比特RSA公钥、40比特对称密钥的加密。显然，攻破此协议并不太难